



OISTE/WISeKey Wi-SUN CP/CPS

Version 1.0.0

OISTE Policy Approval Authority

March 5, 2025

---

| VERSION | DATE       | MODIFICATION  | AUTHOR        |
|---------|------------|---------------|---------------|
| 1.0.0   | 2025-03-05 | First Version | Pedro Fuentes |

---

# Contents

|                                                                        |           |
|------------------------------------------------------------------------|-----------|
| <b>1. INTRODUCTION</b>                                                 | <b>9</b>  |
| 1.1 Overview                                                           | 9         |
| 1.2 Document name and identification                                   | 10        |
| 1.3 PKI participants                                                   | 10        |
| 1.3.1 Certification authorities                                        | 10        |
| 1.3.2 Registration authorities                                         | 10        |
| 1.3.3 Subscribers (Requestors)                                         | 10        |
| 1.3.4 Relying parties                                                  | 11        |
| 1.3.5 Other participants                                               | 11        |
| 1.4 Certificate usage                                                  | 11        |
| 1.4.1 Appropriate certificate uses                                     | 11        |
| 1.4.2 Prohibited certificate uses                                      | 12        |
| 1.5 Policy administration                                              | 12        |
| 1.5.1 Organization administering the document                          | 12        |
| 1.5.2 Contact person                                                   | 13        |
| 1.5.3 Person determining CPS suitability for the policy                | 13        |
| 1.5.4 CPS approval procedures                                          | 13        |
| 1.6 Definitions and acronyms                                           | 13        |
| <b>2. PUBLICATION AND REPOSITORY RESPONSIBILITIES</b>                  | <b>13</b> |
| 2.1 Repositories                                                       | 13        |
| 2.2 Publication of certification information                           | 14        |
| 2.2.1 Statement on compliance with the Wi-SUN Requirements             | 14        |
| 2.3 Time or frequency of publication                                   | 14        |
| 2.4 Access controls on repositories                                    | 14        |
| <b>3. IDENTIFICATION AND AUTHENTICATION</b>                            | <b>14</b> |
| 3.1 Naming                                                             | 14        |
| 3.1.1 Types of names                                                   | 14        |
| 3.1.2 Need for names to be meaningful                                  | 15        |
| 3.1.3 Anonymity or pseudonymity of subscribers                         | 15        |
| 3.1.4 Rules for interpreting various name forms                        | 15        |
| 3.1.5 Uniqueness of names                                              | 15        |
| 3.1.6 Recognition, authentication, and role of trademarks              | 15        |
| 3.2 Initial identity validation                                        | 16        |
| 3.2.1 Method to prove possession of private key                        | 16        |
| 3.2.2 Authentication of organization identity                          | 16        |
| 3.2.3 Authentication of individual identity                            | 16        |
| 3.2.4 Non-verified subscriber information                              | 17        |
| 3.2.5 Validation of authority                                          | 17        |
| 3.2.6 Criteria for interoperation                                      | 17        |
| 3.3 Identification and authentication for re-key requests              | 17        |
| 3.3.1 Identification and authentication for routine re-key             | 17        |
| 3.3.2 Identification and authentication for re-key after revocation    | 18        |
| 3.4 Identification and authentication for a Certificate Problem Report | 18        |
| <b>4. CERTIFICATE LIFE-CYCLE OPERATIONAL REQUIREMENTS</b>              | <b>18</b> |
| 4.1 Certificate Application                                            | 18        |
| 4.1.1 Who can submit a certificate application                         | 18        |
| 4.1.2 Enrollment process and responsibilities                          | 18        |
| 4.2 Certificate application processing                                 | 19        |
| 4.2.1 Performing identification and authentication functions           | 19        |
| 4.2.2 Approval or rejection of certificate applications                | 19        |
| 4.2.3 Time to process certificate applications                         | 19        |
| 4.3 Certificate issuance                                               | 19        |

|                                                                                  |    |
|----------------------------------------------------------------------------------|----|
| 4.3.1 CA actions during certificate issuance . . . . .                           | 19 |
| 4.3.2 Notification to subscriber by the CA of issuance of certificate . . . . .  | 20 |
| 4.4 Certificate acceptance . . . . .                                             | 20 |
| 4.4.1 Conduct constituting certificate acceptance . . . . .                      | 20 |
| 4.4.2 Publication of the certificate by the CA . . . . .                         | 20 |
| 4.4.3 Notification of certificate issuance by the CA to other entities . . . . . | 20 |
| 4.5 Key pair and certificate usage . . . . .                                     | 20 |
| 4.5.1 Subscriber private key and certificate usage . . . . .                     | 20 |
| 4.5.2 Relying party public key and certificate usage . . . . .                   | 20 |
| 4.6 Certificate renewal . . . . .                                                | 21 |
| 4.6.1 Circumstance for certificate renewal . . . . .                             | 21 |
| 4.6.2 Who may request renewal . . . . .                                          | 21 |
| 4.6.3 Processing certificate renewal requests . . . . .                          | 21 |
| 4.6.4 Notification of new certificate issuance to subscriber . . . . .           | 21 |
| 4.6.5 Conduct constituting acceptance of a renewal certificate . . . . .         | 21 |
| 4.6.6 Publication of the renewal certificate by the CA . . . . .                 | 21 |
| 4.6.7 Notification of certificate issuance by the CA to other entities . . . . . | 21 |
| 4.7 Certificate re-key . . . . .                                                 | 21 |
| 4.7.1 Circumstance for certificate re-key . . . . .                              | 21 |
| 4.7.2 Who may request certification of a new public key . . . . .                | 22 |
| 4.7.3 Processing certificate re-keying requests . . . . .                        | 22 |
| 4.7.4 Notification of new certificate issuance to subscriber . . . . .           | 22 |
| 4.7.5 Conduct constituting acceptance of a re-keyed certificate . . . . .        | 22 |
| 4.7.6 Publication of the re-keyed certificate by the CA . . . . .                | 22 |
| 4.7.7 Notification of certificate issuance by the CA to other entities . . . . . | 22 |
| 4.8 Certificate modification . . . . .                                           | 22 |
| 4.8.1 Circumstance for certificate modification . . . . .                        | 22 |
| 4.8.2 Who may request certificate modification . . . . .                         | 22 |
| 4.8.3 Processing certificate modification requests . . . . .                     | 22 |
| 4.8.4 Notification of new certificate issuance to subscriber . . . . .           | 22 |
| 4.8.5 Conduct constituting acceptance of modified certificate . . . . .          | 22 |
| 4.8.6 Publication of the modified certificate by the CA . . . . .                | 22 |
| 4.8.7 Notification of certificate issuance by the CA to other entities . . . . . | 23 |
| 4.9 Certificate compromise handling, withdrawal and suspension . . . . .         | 23 |
| 4.9.1 Circumstances for cessation of issuance and notification . . . . .         | 23 |
| 4.9.2 Who can request cessation of issuance . . . . .                            | 24 |
| 4.9.3 Procedure for a Certificate Problem Report . . . . .                       | 24 |
| 4.9.4 Grace period . . . . .                                                     | 25 |
| 4.9.5 Time within which the CA must act . . . . .                                | 25 |
| 4.9.6 Obligations of relying parties . . . . .                                   | 25 |
| 4.9.7 CRL issuance frequency . . . . .                                           | 25 |
| 4.9.8 Maximum latency for CRLs . . . . .                                         | 25 |
| 4.9.9 On-line revocation/status checking availability . . . . .                  | 25 |
| 4.9.10 On-line revocation checking requirements . . . . .                        | 26 |
| 4.9.11 Other forms of revocation advertisements available . . . . .              | 26 |
| 4.9.12 Special requirements re key compromise . . . . .                          | 26 |
| 4.9.13 Circumstances for suspension . . . . .                                    | 26 |
| 4.9.14 Who can request suspension . . . . .                                      | 26 |
| 4.9.15 Procedure for suspension request . . . . .                                | 26 |
| 4.9.16 Limits on suspension period . . . . .                                     | 26 |
| 4.10 Certificate status services . . . . .                                       | 26 |
| 4.10.1 Operational characteristics . . . . .                                     | 26 |
| 4.10.2 Service availability . . . . .                                            | 27 |
| 4.10.3 Optional features . . . . .                                               | 27 |
| 4.11 End of subscription . . . . .                                               | 27 |
| 4.12 Key escrow and recovery . . . . .                                           | 27 |

|                                                                              |           |
|------------------------------------------------------------------------------|-----------|
| 4.12.1 Key escrow and recovery policy and practices . . . . .                | 27        |
| 4.12.2 Session key encapsulation and recovery policy and practices . . . . . | 27        |
| <b>5. FACILITY, MANAGEMENT, AND OPERATIONAL CONTROLS</b>                     | <b>27</b> |
| 5.1 Physical controls . . . . .                                              | 27        |
| 5.1.1 Site location and construction . . . . .                               | 28        |
| 5.1.2 Physical access . . . . .                                              | 28        |
| 5.1.3 Power and air conditioning . . . . .                                   | 28        |
| 5.1.4 Water exposures . . . . .                                              | 28        |
| 5.1.5 Fire prevention and protection . . . . .                               | 28        |
| 5.1.6 Media storage . . . . .                                                | 28        |
| 5.1.7 Waste disposal . . . . .                                               | 28        |
| 5.1.8 Off-site backup . . . . .                                              | 28        |
| 5.2 Procedural controls . . . . .                                            | 28        |
| 5.2.1 Trusted roles . . . . .                                                | 29        |
| 5.2.2 Number of persons required per task . . . . .                          | 29        |
| 5.2.3 Identification and authentication for each role . . . . .              | 29        |
| 5.2.4 Roles requiring separation of duties . . . . .                         | 29        |
| 5.3 Personnel controls . . . . .                                             | 29        |
| 5.3.1 Qualifications, experience, and clearance requirements . . . . .       | 29        |
| 5.3.2 Background check procedures . . . . .                                  | 29        |
| 5.3.3 Training requirements . . . . .                                        | 29        |
| 5.3.4 Retraining frequency and requirements . . . . .                        | 30        |
| 5.3.5 Job rotation frequency and sequence . . . . .                          | 30        |
| 5.3.6 Sanctions for unauthorized actions . . . . .                           | 30        |
| 5.3.7 Independent contractor requirements . . . . .                          | 30        |
| 5.3.8 Documentation supplied to personnel . . . . .                          | 30        |
| 5.4 Audit logging procedures . . . . .                                       | 30        |
| 5.4.1 Types of events recorded . . . . .                                     | 30        |
| 5.4.2 Frequency of processing log . . . . .                                  | 31        |
| 5.4.3 Retention period for audit log . . . . .                               | 31        |
| 5.4.4 Protection of audit log . . . . .                                      | 31        |
| 5.4.5 Audit log backup procedures . . . . .                                  | 31        |
| 5.4.6 Audit collection system (internal vs. external) . . . . .              | 31        |
| 5.4.7 Notification to event-causing subject . . . . .                        | 31        |
| 5.4.8 Vulnerability assessments . . . . .                                    | 31        |
| 5.5 Records archival . . . . .                                               | 31        |
| 5.5.1 Types of records archived . . . . .                                    | 31        |
| 5.5.2 Retention period for archive . . . . .                                 | 31        |
| 5.5.3 Protection of archive . . . . .                                        | 31        |
| 5.5.4 Archive backup procedures . . . . .                                    | 32        |
| 5.5.5 Requirements for time-stamping of records . . . . .                    | 32        |
| 5.5.6 Archive collection system (internal or external) . . . . .             | 32        |
| 5.5.7 Procedures to obtain and verify archive information . . . . .          | 32        |
| 5.6 Key changeover . . . . .                                                 | 32        |
| 5.7 Compromise and disaster recovery . . . . .                               | 32        |
| 5.7.1 Incident and compromise handling procedures . . . . .                  | 32        |
| 5.7.2 Computing resources, software, and/or data are corrupted . . . . .     | 32        |
| 5.7.3 Entity private key compromise procedures . . . . .                     | 33        |
| 5.7.4 Business continuity capabilities after a disaster . . . . .            | 33        |
| 5.8 CA or RA termination . . . . .                                           | 33        |
| <b>6. TECHNICAL SECURITY CONTROLS</b>                                        | <b>34</b> |
| 6.1 Key pair generation and installation . . . . .                           | 34        |
| 6.1.1 Key pair generation . . . . .                                          | 34        |
| 6.1.2 Private key delivery to subscriber . . . . .                           | 34        |
| 6.1.3 Public key delivery to certificate issuer . . . . .                    | 35        |

|                                                                                      |           |
|--------------------------------------------------------------------------------------|-----------|
| 6.1.4 CA public key delivery to relying parties . . . . .                            | 35        |
| 6.1.5 Key sizes . . . . .                                                            | 35        |
| 6.1.6 Public key parameters generation and quality checking . . . . .                | 35        |
| 6.1.7 Key usage purposes (as per X.509 v3 key usage field) . . . . .                 | 36        |
| 6.2 Private Key Protection and Cryptographic Module Engineering Controls . . . . .   | 36        |
| 6.2.1 Cryptographic module standards and controls . . . . .                          | 36        |
| 6.2.2 Private key (n out of m) multi-person control . . . . .                        | 36        |
| 6.2.3 Private key escrow . . . . .                                                   | 36        |
| 6.2.4 Private key backup . . . . .                                                   | 36        |
| 6.2.5 Private key archival . . . . .                                                 | 36        |
| 6.2.6 Private key transfer into or from a cryptographic module . . . . .             | 37        |
| 6.2.7 Private key storage on cryptographic module . . . . .                          | 37        |
| 6.2.8 Method of activating private key . . . . .                                     | 37        |
| 6.2.9 Method of deactivating private key . . . . .                                   | 37        |
| 6.2.10 Method of destroying private key . . . . .                                    | 37        |
| 6.2.11 Cryptographic Module Rating . . . . .                                         | 37        |
| 6.3 Other aspects of key pair management . . . . .                                   | 37        |
| 6.3.1 Public key archival . . . . .                                                  | 38        |
| 6.3.2 Certificate operational periods and key pair usage periods . . . . .           | 38        |
| 6.4 Activation data . . . . .                                                        | 38        |
| 6.4.1 Activation data generation and installation . . . . .                          | 38        |
| 6.4.2 Activation data protection . . . . .                                           | 39        |
| 6.4.3 Other aspects of activation data . . . . .                                     | 39        |
| 6.5 Computer security controls . . . . .                                             | 39        |
| 6.5.1 Specific computer security technical requirements . . . . .                    | 39        |
| 6.5.2 Computer security rating . . . . .                                             | 39        |
| 6.6 Life cycle technical controls . . . . .                                          | 39        |
| 6.6.1 System development controls . . . . .                                          | 39        |
| 6.6.2 Security management controls . . . . .                                         | 39        |
| 6.6.3 Life cycle security controls . . . . .                                         | 39        |
| 6.7 Network security controls . . . . .                                              | 40        |
| 6.8 Time-stamping . . . . .                                                          | 40        |
| <b>7. CERTIFICATE PROFILES</b>                                                       | <b>40</b> |
| 7.1 Certificate profile . . . . .                                                    | 40        |
| 7.1.1 Version number(s) . . . . .                                                    | 41        |
| 7.1.2 Certificate extensions . . . . .                                               | 41        |
| 7.1.3 Algorithm object identifiers . . . . .                                         | 43        |
| 7.1.4 Name forms . . . . .                                                           | 43        |
| 7.1.5 Name constraints . . . . .                                                     | 43        |
| 7.1.6 Certificate policy object identifier . . . . .                                 | 44        |
| 7.1.7 Usage of Policy Constraints extension . . . . .                                | 44        |
| 7.1.8 Policy qualifiers syntax and semantics . . . . .                               | 44        |
| 7.1.9 Processing semantics for the critical Certificate Policies extension . . . . . | 44        |
| 7.2 CRL profile . . . . .                                                            | 44        |
| 7.3 OCSP profile . . . . .                                                           | 44        |
| <b>8. COMPLIANCE AUDIT AND OTHER ASSESSMENTS</b>                                     | <b>44</b> |
| 8.1 Frequency or circumstances of assessment . . . . .                               | 44        |
| 8.2 Identity/qualifications of assessor . . . . .                                    | 45        |
| 8.3 Assessor's relationship to assessed entity . . . . .                             | 45        |
| 8.4 Topics covered by assessment . . . . .                                           | 45        |
| 8.5 Actions taken as a result of deficiency . . . . .                                | 46        |
| 8.6 Communication of results . . . . .                                               | 46        |
| <b>9. OTHER BUSINESS AND LEGAL MATTERS</b>                                           | <b>46</b> |
| 9.1 Fees . . . . .                                                                   | 46        |

|                                                                              |           |
|------------------------------------------------------------------------------|-----------|
| 9.1.1 Certificate issuance or renewal fees . . . . .                         | 46        |
| 9.1.2 Certificate access fees . . . . .                                      | 46        |
| 9.1.3 Revocation or status information access fees . . . . .                 | 46        |
| 9.1.4 Fees for other services . . . . .                                      | 46        |
| 9.1.5 Refund policy . . . . .                                                | 47        |
| 9.2 Financial responsibility . . . . .                                       | 47        |
| 9.2.1 Insurance coverage . . . . .                                           | 47        |
| 9.2.2 Other assets . . . . .                                                 | 47        |
| 9.2.3 Insurance or warranty coverage for end-entities . . . . .              | 47        |
| 9.3 Confidentiality of business information . . . . .                        | 47        |
| 9.3.1 Scope of confidential information . . . . .                            | 47        |
| 9.3.2 Information not within the scope of confidential information . . . . . | 47        |
| 9.3.3 Responsibility to protect confidential information . . . . .           | 48        |
| 9.4 Privacy of personal information . . . . .                                | 48        |
| 9.4.1 Privacy plan . . . . .                                                 | 48        |
| 9.4.2 Information treated as private . . . . .                               | 48        |
| 9.4.3 Information not deemed private . . . . .                               | 48        |
| 9.4.4 Responsibility to protect private information . . . . .                | 48        |
| 9.4.5 Notice and consent to use private information . . . . .                | 48        |
| 9.4.6 Disclosure pursuant to judicial or administrative process . . . . .    | 48        |
| 9.4.7 Other information disclosure circumstances . . . . .                   | 48        |
| 9.5 Intellectual property rights . . . . .                                   | 49        |
| 9.6 Representations and warranties . . . . .                                 | 49        |
| 9.6.1 CA representations and warranties . . . . .                            | 49        |
| 9.6.2 RA representations and warranties . . . . .                            | 49        |
| 9.6.3 Subscriber representations and warranties . . . . .                    | 49        |
| 9.6.4 Relying party representations and warranties . . . . .                 | 50        |
| 9.6.5 Representations and warranties of other participants . . . . .         | 51        |
| 9.7 Disclaimers of warranties . . . . .                                      | 51        |
| 9.8 Limitations of liability . . . . .                                       | 51        |
| 9.9 Indemnities . . . . .                                                    | 51        |
| 9.10 Term and termination . . . . .                                          | 51        |
| 9.10.1 Term . . . . .                                                        | 51        |
| 9.10.2 Termination . . . . .                                                 | 51        |
| 9.10.3 Effect of termination and survival . . . . .                          | 51        |
| 9.11 Individual notices and communications with participants . . . . .       | 52        |
| 9.12 Amendments . . . . .                                                    | 52        |
| 9.12.1 Procedure for amendment . . . . .                                     | 52        |
| 9.12.2 Notification mechanism and period . . . . .                           | 52        |
| 9.12.3 Circumstances under which OID must be changed . . . . .               | 52        |
| 9.13 Dispute resolution provisions . . . . .                                 | 52        |
| 9.14 Governing law . . . . .                                                 | 52        |
| 9.15 Compliance with applicable law . . . . .                                | 53        |
| 9.16 Miscellaneous provisions . . . . .                                      | 53        |
| 9.16.1 Entire agreement . . . . .                                            | 53        |
| 9.16.2 Assignment . . . . .                                                  | 53        |
| 9.16.3 Severability . . . . .                                                | 53        |
| 9.16.4 Enforcement (attorneys' fees and waiver of rights) . . . . .          | 53        |
| 9.16.5 Force Majeure . . . . .                                               | 53        |
| 9.17 Other provisions . . . . .                                              | 53        |
| <b>Appendix A: Glossary</b>                                                  | <b>53</b> |
| Acronyms . . . . .                                                           | 53        |
| Definitions . . . . .                                                        | 54        |
| <b>Appendix B: CA Hierarchies</b>                                            | <b>57</b> |
| Wi-SUN Root . . . . .                                                        | 57        |

---

|                                                                       |           |
|-----------------------------------------------------------------------|-----------|
| Ownership and governance . . . . .                                    | 57        |
| Root Information . . . . .                                            | 57        |
| Subordinate CA Information . . . . .                                  | 58        |
| Retired Subordinate CAs . . . . .                                     | 58        |
| <b>Appendix C: OID Inventory</b>                                      | <b>58</b> |
| External object identifiers used in the certificate profile . . . . . | 58        |
| <b>Appendix D: Adopted Wi-SUN Requirements</b>                        | <b>59</b> |

# 1. INTRODUCTION

This document represents a combined Certificate Policy (CP) and Certification Practice Statement (CPS), and describes the practices followed with regard to the management of the lifecycle the Certification Authorities adhered to the OISTE/WISeKey Global Trust Model (OWGTM from now on) for the purposes of Wi-SUN FAN devices.

## 1.1 Overview

The main two legal entities involved in the control and operation of the OISTE/WISeKey Global Trust Model are: - OISTE Foundation. The International Organization for Secure Electronic Transactions (“IOSET” or “OISTE”), a Swiss non-profit foundation established in 1998, and recognized with an “Special Consultative Status” by the United Nations. The OISTE Foundation maintains a Policy Approval Authority (PAA) that drafts, approves and revises the policies to which WISeKey is bound to comply with under its operator contract. The PAA is composed of members of the community to which OISTE provides its Certification Authority Services, resulting in a virtuous cycle for trust management. - WISeKey. WISeKey is referenced in this document as the short name for the entities “WISeKey International Holding Ltd.”, “WISeKey SA”, “SEALSQ Corp.” or other members of the WISeKey Holding that are mandated by OISTE to own, host and operate the Root Certification Authorities and the technical infrastructures required to maintain the PKI at the appropriate operational level. The Root CA identified in Appendix B is owned by SEALSQ Corp. and is within this definition. WISeKey also operates as a “Subordinate Certification Authority” under the OISTE Roots, according to practices disclosed in this document.

The OISTE Global Trust Model (OWGTM) has been designed and are operated in accordance with the broad strategic direction of international PKI (Public Key Infrastructure) standards as well as their application to concrete identity frameworks in different domains (e.g. ID cards, passports, health cards, Internet of Things) and is intended to serve as a common Trust Model for Certification Authorities worldwide that comply with OISTE requirements.

The technologies, infrastructures, practices, and procedures implemented by the OWGTM have been designed with explicit standards of security in mind based on the requirements approved by OISTE.

The OISTE Foundation, under Swiss law, cannot belong to any individual or company. It is subject to annual supervision by the Swiss Federal Government and audited annually by independent auditors. Such supervision and audit require the foundation to pursue the objectives that have been set out for it, which includes the promotion of security in electronic communications worldwide.

This document is developed per the recommendations found in the document RFC3647, developed by the Internet Engineering Task Force (IETF), which has been adopted as a worldwide-recognized standard framework to document the Certifications Practice Statement and related Certificate Policies disclosed by a Certification Services Provider.

The purpose of this document is to disclose the Practices and Policies adopted in the OWGTM for the issuance of digital certificates. It is organized in the following sections: 1. Introduction – This section. Introduces the OWGTM and this document. 2. Publication and Repositories Responsibilities – Describes the publication policies for the certificates affected by this document, and the publication of this document itself. 3. Identification and Authentication – Discloses the rules for subscriber naming and required authentication policies. 4. Certificate Life-Cycle Operational Requirements – This section describes the different phases in the Life-Cycle of certificates and their requirements. 5. Management, Operational and Physical Controls – Describes the controls enforced in the OWGTM to provide adequate trust levels in the certificates issued under the Trust Model. 6. Technical Security Controls – Discloses the security controls adopted in the OWGTM. 7. Certificate Profiles – Describes the technical details of the different certificate types issued under the OWGTM. 8. Compliance Audit and other Assessment – Discloses the audit policies followed in the OWGTM to ensure that the participant fulfils the security and quality requirements. 9. Other Business and Legal Matters – This section exposes the commercial, legal and contractual aspects involved in the usage of certificates issued in the OWGTM.

**APPLICABILITY NOTICE:** If any inconsistency exists between this document and the normative provisions of a Wi-SUN Requirement (as defined in Appendix A and listed in Appendix D), then the Wi-SUN

Requirement takes precedence over this CP/CPS, and the PAA shall amend this document at the next revision.

## 1.2 Document name and identification

|               |                                                                                                                                                                                                                |
|---------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Name          | OISTE/WISeKey Wi-SUN Certificate<br>Policy/Certification Practices Statement (CP/CPS)                                                                                                                          |
| Version       | 1.0.0                                                                                                                                                                                                          |
| Issuance date | 2025-03-05                                                                                                                                                                                                     |
| Location      | This document is also published in<br><a href="https://github.com/oiste/repository">https://github.com/oiste/repository</a> and<br><a href="https://wisekey.com/repository">https://wisekey.com/repository</a> |

## 1.3 PKI participants

The following sections describe the different participant types in the OWGTM.

### 1.3.1 Certification authorities

OISTE and WISeKey own and operate a number of Root and Issuing Certification Authority (CA) hierarchies that deliver certification services under the OWGTM.

The Root CA that anchors the Wi-SUN hierarchy is an exception to that ownership: it is owned by SealSQ Corp., while the trust model, policies and certification practices applied beneath it are regulated by the OISTE Foundation through its Policy Approval Authority. This is set out in Appendix B, where the hierarchy is detailed. The Root CA is dedicated to the Wi-SUN ecosystem and is recognised by the Wi-SUN Alliance as an approved third-party Certification Authority root.

### 1.3.2 Registration authorities

The Registration Authorities are the physical or legal persons responsible for the identification of the entities requesting a certificate (referred as “applicants” when the request is in process and “subscribers” for those in possession of a certificate). The OWGTM delegates to Registration Authorities the responsibility of verifying the information provided by the applicant within a certificate request, ensuring that the request and the process used to deliver the certificate to the subscriber meets the requirements of this CPS and the appropriate CP.

The Registration Authorities in the OWGTM are directly supervised by the CA and follow an accreditation process imposed by the CA in order to ensure that all security and operational procedures related to the certificates life-cycle are strictly enforced. Within the OWGTM environment there exist locations named “OWGTM Registration Point” that are the physical or virtual locations where a Registration Authority operates. These Registration Points are operated by “Registration Authority Officers”, who are authorized persons responsible for verifying the identity and veracity of a certificate request for an end entity and the delivery of the certificate once issued by the Certification Authority.

Therefore, the responsibilities of Registration Authorities operating under the OWGTM are as follows: - Check the identity and circumstances needed to verify that a certificate request is valid according to the type of certificate requested. - Inform the applicant, before the issuance of the certificate, about the terms and conditions related to the certificate and its usage. - Verify that the information contained in a certificate is exact and complete according to the requirements of the corresponding CP. - Ensure that the subscriber is in possession of the digital signature creation data (private keys) associated to the certificate to be issued.

### 1.3.3 Subscribers (Requestors)

In the OWGTM two different end-user roles are defined. Depending on the status of the certificate request, these roles are named “Applicant” and “Subscriber”. In particular, for Wi-SUN IDevIDs the Subscriber is the Manufacturer of the device, which SHALL be a Promoter or Contributor member of the Wi-SUN Alliance holding a current Proof of Wi-SUN Membership (POWM), as verified under section 3.2.2. The device itself is

the subject of the certificate but is not the Subscriber. - An applicant is a physical person that requests a certificate for his own behalf or on behalf of a third party. The applicant needs to accredit his identity and ability to request a certificate. In the case of an applicant acting on behalf of a third party or legal person, he will be requested to accredit the empowerment for such representation, as required by law. - A subscriber is the physical or legal person whose identity is linked to the electronic signature creation data, or private key, and included in a digital certificate. In general, a subscriber is considered the “owner” of a certificate. The subscriber of a certificate is responsible for the custody of his private key and not communicating this data in any way to any other person.

This document details the particular community of subscribers to whom each type of certificate is aimed and what identification and other security requirements should be fulfilled.

### 1.3.4 Relying parties

All natural and legal persons and other entities that trust the certificates issued by certification authorities operating under the OWGTM Trust Model are considered to be “relying parties”. These relying parties do not necessarily need to be a subscriber of an OWGTM certificate, but are requested to accept the “CertifyID Relying Party Agreement”, available at <http://oiste.org/repository>, which applies to relying parties of Wi-SUN IDevIDs.

In the Wi-SUN context the relying parties are, in practice: - the **network operator**, through the Authentication Server that terminates EAP-TLS for the Field Area Network and the Border Router that admits nodes and manages group keys; and - **other Wi-SUN FAN nodes**, when performing node-to-node pairwise authentication.

Both categories validate an IDevID against a trust anchor provisioned in advance, as described in section 6.1.4, and both carry the obligations of section 9.6.4, which in this hierarchy include obligations that elsewhere would be discharged by revocation checking.

In the OWGTM, a particular type of certificate could limit the right to be a relying party for that particular type of certificate, if this is the case, a specific Relying Party agreement would be published.

### 1.3.5 Other participants

No stipulation.

## 1.4 Certificate usage

In the OWGTM, the limitations for certificate usage are established for each particular certificate type. This information is summarized in the following subsections. The type of certificate is determined by the combination of “Key Usage”, “Extended Key Usage”, and Policy Identifiers.

In the context of Wi-SUN, certificate usage must be aligned with the Wi-SUN Requirements adopted by the PAA and listed in Appendix D.

### 1.4.1 Appropriate certificate uses

| Certificate type                         | Description                                                                                                                                                                                                                                                                                                                    | Permitted uses      |
|------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|
| Wi-SUN Manufacturer CA (MCA) Certificate | Infrastructure certificate for a Manufacturer Certification Authority, subordinate to the Root CA and authorised to issue Wi-SUN Manufacturer Issuing CA certificates. It does not issue Wi-SUN IDevIDs directly. It may be operated by WISeKey on behalf of a Manufacturer, or by the Manufacturer itself under section 3.2.6 | Certificate Signing |

| Certificate type                                  | Description                                                                                                                                                                                                                                                                                                                                     | Permitted uses                                                                                                                         |
|---------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------|
| Wi-SUN Manufacturer Issuing CA (MICA) Certificate | Infrastructure certificate for a Manufacturer Issuing Certification Authority, authorised to issue Wi-SUN IDevIDs. It is subordinate either to an MCA or directly to the Root CA, as stated in section 7.1. It may be operated by WISEKey on behalf of a Manufacturer, or by the Manufacturer itself under section 3.2.6                        | Certificate Signing                                                                                                                    |
| Wi-SUN IDevID                                     | Initial Device Identifier, in the sense of IEEE 802.1AR, installed in a Wi-SUN FAN device at manufacture. It authenticates the device to a Field Area Network during EAP-TLS network access authentication, and in node-to-node pairwise authentication. It identifies the device by the hardware module identifiers described in section 7.1.4 | Digital Signature; Key Agreement (optional); Client Authentication; Wi-SUN FAN device authentication ( <b>id-kp-wisun-fan-device</b> ) |

#### 1.4.2 Prohibited certificate uses

In general, any usage that is not explicitly stated in section 1.4.1 of this document or the appropriate CP is considered to be prohibited. In particular:

- **Test IDevIDs are out of scope.** Certificates issued for Wi-SUN FAN certification and interoperability testing are issued from the separate test hierarchy maintained for that purpose in the Wi-SUN programme. That hierarchy is not trusted for production networks and is not covered by this CP/CPS. Every certificate issued under this CP/CPS is a Production IDevID, and a Manufacturer holding both test and production accounts must not confuse the two.
- **LDevIDs are out of scope.** Locally significant device identifiers, issued by a network operator to a node after enrolment, are not issued under this CP/CPS. Where an operator issues LDevIDs, it does so under its own policy and assumes the corresponding responsibilities, including their expiry and revocation.
- A Wi-SUN IDevID SHALL NOT be used for any purpose other than Field Area Network access authentication and node-to-node pairwise authentication. It is not a TLS server certificate, a code-signing certificate, or a general-purpose client certificate, notwithstanding the presence of **id-kp-clientAuth**, which is required by the Wi-SUN Requirements for EAP-TLS interoperability.

## 1.5 Policy administration

This section describes how this document is administered. The same practices apply to all policies adopted by the OWGTM.

### 1.5.1 Organization administering the document

This document is administered by the OWGTM Policy Approval Authority (referred from now as PAA).

The PAA has a series of distinct functions but does not operate as a separate legal Entity. It is managed and organized in accordance with a process that draws on expertise within the OISTE Foundation and WISEKey. The PAA has been established to develop, review and/or approve the practices, policies and procedures for the

entire Trust Model, subject to guidelines established by the members and advisors of the OISTE Foundation and WISEKey.

### 1.5.2 Contact person

- **Name:** OISTE Foundation - OWGTM Policy Approval Authority
- **email address:** [cps@oiste.org](mailto:cps@oiste.org), [cps@wisekey.com](mailto:cps@wisekey.com)
- **Address:** Avenue Louis-Casaï 58 - 1216 Cointrin - Switzerland

This same contact can also be used for Certificate Problem Reports under section 4.9.3 and for compliance-related notifications.

### 1.5.3 Person determining CPS suitability for the policy

The competent entity which determines the compliance and suitability of all CPS and the different supported CPs on behalf of the entire Trust Model is the OWGTM PAA.

### 1.5.4 CPS approval procedures

The OWGTM PAA defines and executes the procedures related to the approval of the CPS and CP and its subsequent amendments. Amendments will produce a new version of the document that will be published in the OWGTM Policy Repository (specified in section 2.1 of this document).

The approval of major changes of documents related to the PKI, and specially for the CP/CPS, require a meeting of the PAA and the issuance of an approval memo signed by at least two members of the PAA. Minor versions only require the participation of a single member of the PAA in order to approve the publication of a new version.

It's required to issue new CP/CPS versions at least once a year. In the case of versioning conflict, the latest version that prevails is always the document published in the Policy Repository.

Once any document of the Trust Model is updated, the CAs must do a technical assessment to identify any possible impact and/or required configuration changes in the platforms.

## 1.6 Definitions and acronyms

Definitions and Acronyms are included in Appendix A

## 2. PUBLICATION AND REPOSITORY RESPONSIBILITIES

The Root CA certificate and the Subordinate CA certificates of the Wi-SUN hierarchy are published in the OWGTM Policies repository identified in section 2.1, and are listed in Appendix B.

### 2.1 Repositories

The main repositories of the OWGTM are: - Policies repository for disclosure of CP/CPS and related information. This repository is a set of web pages and services available at the URLs <https://oiste.org> and <https://github.com/oiste/repository> - Certificate repository. The OWGTM makes the Wi-SUN Root CA and Subordinate CA certificates, and the **chain bundles** described in section 6.1.4, publicly accessible to Manufacturers and to network operators through the repository identified above. No revocation information source is published, and no CDP or AIA extension is present in any certificate of the Wi-SUN hierarchy, as stated in section 7.1.2. - Notices. The repository also publishes the compromise and retirement notices described in section 4.9.1, which are the only status information available for this hierarchy.

Should the Wi-SUN Alliance establish a certificate repository of its own, and the PAA adopt it as a Wi-SUN Requirement, it will be listed in Appendix D and used in addition to the OWGTM repository.

## 2.2 Publication of certification information

The OWGTM is responsible for publication of information regarding practices, certificates, and the current status of certificates. Where appropriate, such responsibilities may be delegated to the Subordinate CAs operating under the OISTE Trust Model.

The shared repositories containing public information in the OWGTM are managed by WISeKey SA or the operator of the Issuing CAs, and are available 24 hours a day, seven days a week. In the case of interruption by cause of “force majeure”, the service will be re-established in the minimum possible time.

### 2.2.1 Statement on compliance with the Wi-SUN Requirements

OISTE and WISeKey ensure compliance with industry best practices and security controls. In particular, the trust model enforces a regular review of the documents published by the Wi-SUN Alliance that are applicable to PKI services, certificate profiles or device identity. Those that the PAA formally adopts for the Wi-SUN hierarchy become “Wi-SUN Requirements” and are listed, with title, version and date of adoption, in Appendix D.

In the case of a discrepancy between any certification practice stated in this CP/CPS and a Wi-SUN Requirement, the Wi-SUN Requirement prevails, and the PAA shall amend this document at the next revision.

Where no Wi-SUN Requirement governs a given matter, this CP/CPS is self-contained and its own stipulations apply.

The Wi-SUN Alliance approves the Certification Authorities permitted to issue Wi-SUN IDevIDs, and requires the Manufacturer to hold membership, but it does **not** evaluate or audit those Certification Authorities and accepts no responsibility for their security. Assurance as to the practices described in this CP/CPS therefore rests on the assessments of section 8 and on nothing else. Relying parties should read section 8 and section 9.7 together before relying on a Wi-SUN IDevID.

## 2.3 Time or frequency of publication

The CP/CPS documents will be published every time they are modified, with a minimum review period of one year.

CA certificates and chain bundles are published as soon as they are available. **Wi-SUN IDevIDs are not published:** they are delivered to the Manufacturer for installation in the device at manufacture, and the OWGTM does not operate a public directory of issued device certificates.

No revocation information is published, because no certificate in this hierarchy is subject to revocation. The compromise and retirement notices of section 4.9.1 are published within the deadlines of section 4.9.5.

## 2.4 Access controls on repositories

The OWGTM makes its Repository publicly available in a read-only manner.

# 3. IDENTIFICATION AND AUTHENTICATION

The OWGTM mandates the fulfillment of a set of required minimum controls that ensure the authenticity of the data included in certificates. These controls are enforced during the full lifecycle of certificates, certificate requests, and related documents

## 3.1 Naming

This section describes the elements regarding naming and identifying the subscribers of OWGTM certificates.

### 3.1.1 Types of names

Two distinct naming schemes are used in the Wi-SUN hierarchy.

**CA certificates** are assigned a Distinguished Name (DN) according to the X.501 Standard, composed of a Common Name (CN), an Organization (O) and a Country (C), as stated in section 7.1.4.

**Wi-SUN IDevIDs have an empty subject field.** They carry no Distinguished Name at all. The device is identified instead by a single **otherName** of type **id-on-hardwareModuleName** in the **subjectAltName** extension, which is marked critical, comprising the hardware type OID (**hwType**) and the device serial number (**hwSerialNum**). This is required by the Wi-SUN Requirements: a Wi-SUN FAN node ignores the subject field during path validation, and the identity that matters to the network is the hardware module name.

### 3.1.2 Need for names to be meaningful

For CA certificates, all Distinguished Names must be meaningful, and the attributes identifying the subscriber should be in human-readable form.

For Wi-SUN IDevIDs the requirement does not apply in that form, there being no Distinguished Name. The **hwType** and **hwSerialNum** values are machine identifiers, not human-readable names. They are nonetheless meaningful in the sense that matters here: **hwType** resolves, through the IANA Private Enterprise Number registry, to the Manufacturer that owns the arc, and the pairing of **hwType** with **hwSerialNum** resolves, through the records the CA retains under section 5.5, to a single manufactured device.

### 3.1.3 Anonymity or pseudonymity of subscribers

Wi-SUN PKI CAs SHALL NOT issue anonymous or pseudonymous Certificates.

An empty subject field in a Wi-SUN IDevID is not anonymity. The device is identified by the hardware module name in the critical **subjectAltName** extension, and the Manufacturer responsible for it is identified by the Private Enterprise Number arc of the **hwType** value and by the issuing Subordinate CA, whose records identify the Subscriber.

### 3.1.4 Rules for interpreting various name forms

The rules used in the OWGTM to interpret the distinguished names of CA certificates are defined by the ISO/IEC 9595 (X.500) Distinguished Name (DN) standard.

The hardware module name of a Wi-SUN IDevID is interpreted as defined in RFC 4108, with **hwType** an OBJECT IDENTIFIER beneath the Manufacturer's IANA Private Enterprise Number arc and **hwSerialNum** an OCTET STRING, as detailed in section 7.1.4.

### 3.1.5 Uniqueness of names

For CA certificates, OWGTM requires uniqueness of the Subject DN across the certificates issued by the Roots, except in the case of re-issuances for the same entity.

For Wi-SUN IDevIDs, subject-name uniqueness is meaningless because the subject is empty. Uniqueness is enforced on two other values instead:

- **Certificate serial number**, which is unique within the issuing Certification Authority. The OWGTM generates serial numbers containing at least 12 octets of entropy from a random source within the issuing cryptographic module, as stated in section 7.1.4.
- **The pair **hwType** + **hwSerialNum****, which is unique across all certificates issued to a given Manufacturer. The Manufacturer warrants this uniqueness under section 9.6.3, and the issuing Certification Authority rejects an enrolment request carrying a pair it has issued before.

Because a Wi-SUN IDevID cannot be revoked or re-issued in the field, a duplicate **hwSerialNum** cannot be corrected once devices are in service. The check is therefore performed at issuance and cannot be deferred.

### 3.1.6 Recognition, authentication, and role of trademarks

The inclusion of a name in a certificate does not imply any right over that name, neither for the OWGTM nor the applicant, nor the subscriber. The OWGTM reserves the right to refuse a certificate request if a conflict is detected over ownership or copyright of a name. A certificate already issued cannot be revoked; where a

conflict emerges after issuance the OWGTM ceases issuance for the affected identifiers and publishes a notice under section 4.9.1.

In any event, the OWGTM will not attempt to intermediate nor resolve conflicts regarding ownership of names or trademarks.

## 3.2 Initial identity validation

OWGTM performs “face to face” (or equivalent) identity validation for the certificates issued by the Roots. Stipulations related to subscriber certificates are defined in the following sections.

### 3.2.1 Method to prove possession of private key

If the key pair is generated by the End Entity (applicant or future subscriber), then a demonstration of the possession of the private key associated to the public key is requested. Accepted means are the generation of a Certificate Signing Request (CSR) linked to the private key, or any other method accepted by OWGTM.

If (when allowed by the applicable regulations) the key pair is generated by the CA or the RA, OWGTM defines and enforces approved procedures to transfer securely the private key to the subscriber (i.e. sending PFX files and passwords by different channels, and deleting any signature private key once the transfer is effective).

### 3.2.2 Authentication of organization identity

Before issuing a certificate for a subordinate Certification Authority OWGTM requires the fulfillment of a legally binding agreement between the organization and the OISTE Foundation, which includes the appropriate validation of the organization identity and signatories of the agreement.

Where a Manufacturer applies to operate its own Wi-SUN Subordinate CA, the OWGTM additionally verifies, before the Subordinate CA Certificate is issued, that the Manufacturer meets the accreditation criteria of section 3.2.6, that the Subordinate CA will be constrained by configuration to the Private Enterprise Number arc the Manufacturer is entitled to use as stated in section 7.1.5, that the tier at which the Subordinate CA will operate is recorded, MCA or MICA, together with the chain shape it will form under section 7.1, and that the Manufacturer accepts the audit obligations of section 8.4.

A Manufacturer applying to operate an MCA is additionally assessed on its ability to run the certification of its own MICAs to the standard of this CP/CPS, since an MCA certifies Certification Authorities rather than devices and a fault at that tier propagates to every MICA beneath it.

#### 3.2.2.1 For Device Certificates

| CP Identifier | Validation Policy                            |
|---------------|----------------------------------------------|
| Wi-SUN IDevID | The Registration Authority must verify that: |

### 3.2.3 Authentication of individual identity

The following subsections describe the required practices for each subscriber certificate type.

#### 3.2.3.1 For Device Certificates

| CP Identifier | Validation Policy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|---------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Wi-SUN IDevID | <p><b>ID Data Verified:</b>The <b>hwType</b> OBJECT IDENTIFIER and the <b>hwSerialNum</b> of the individual device, which together form the hardware module name placed in the certificate.</p> <p><b>Method of Verification:</b>The Manufacturer identity and its entitlement to the Private Enterprise Number beneath which <b>hwType</b> is allocated are verified as stated in section 3.2.2. The <b>hwSerialNum</b> is taken from the Manufacturer's production record for the unit concerned; the CA accepts it on the basis of the Manufacturer's warranty in the Subscriber Agreement that each <b>hwSerialNum</b> is unique within its <b>hwType</b> and identifies a single physical device. Enrolment requests must originate from a production system authenticated to the issuing Certification Authority, and the issuing Certification Authority SHALL reject any request whose <b>hwType</b> falls outside the Private Enterprise Number arc recorded for that Manufacturer under section 3.2.2.</p> <p><b>Entities authorized to verify:</b></p> |

### 3.2.4 Non-verified subscriber information

All attributes included in a certificate that are subject to the Wi-SUN Requirements or to this CP/CPS must undergo appropriate validation. No unverified subscriber information is included in Wi-SUN IDevIDs.

### 3.2.5 Validation of authority

The CA's Certificate issuance process SHALL confirm that: - The corporate contact listed in the Registration Authority Declaration (the signed enrolment record establishing the organization's authorised contacts, "RAD") is an officer of the organization who can sign on its behalf and bind it to the terms and conditions of the agreement; - The representative submitting the RAD and the Certificate Application is authorized to act on behalf of the organization; - The administrators listed in the RAD are authorized to act on behalf of the organization; and - The contacts listed in the RAD are authorized to act on behalf of the organization.

### 3.2.6 Criteria for interoperation

A Certification Authority that wishes to interoperate with the OWGTM is required to undergo an internal accreditation process to ensure the compliance with this CPS.

If this accreditation process is successful, it will result in the creation of an "Issuing CA" under the OWGTM that adheres to this CPS and authorized to issue certain Certificate Types.

## 3.3 Identification and authentication for re-key requests

Wi-SUN IDevIDs do not expire and are not revoked, so there is no occasion on which one must be re-keyed or renewed. Where a device requires a different identity, a new Wi-SUN IDevID is issued to it under the full initial identification procedures of section 3.2; this is a new issuance, not a re-key. The provisions below therefore apply to Registration Authority operator certificates and to CA certificates only.

### 3.3.1 Identification and authentication for routine re-key

The certificate subscriber can request a routine re-key by authenticating himself with one of these methods: - Username & Password - A valid digital certificate linked to the user account

### 3.3.2 Identification and authentication for re-key after revocation

Not applicable to Wi-SUN IDevIDs, which are not revoked. For other certificate types, the OWGTM does not support re-key after revocation; the subscriber must apply for a new digital certificate using the same procedures as for its issuance.

## 3.4 Identification and authentication for a Certificate Problem Report

Wi-SUN IDevIDs and the CA certificates in their chain are not subject to revocation, so there are no revocation requests to authenticate. What a Subscriber or a third party may submit instead is a Certificate Problem Report under section 4.9.3, on which the Certification Authority ceases issuance, notifies and publishes.

A Certificate Problem Report is authenticated in proportion to the action it would trigger. A report that would cause the CA to cease issuing for a Manufacturer, or to publish a compromise notice naming it, SHALL be corroborated before that action is taken: by authentication of the reporting party against its enrolment record, by a demonstration of key compromise under section 4.9.12, or by the CA's own investigation. An unauthenticated report is investigated but does not by itself trigger publication, since publication cannot be withdrawn from the operators who have already acted on it.

## 4. CERTIFICATE LIFE-CYCLE OPERATIONAL REQUIREMENTS

The stipulations included in this section are understood as common for all the certificates issued under the OWGTM Root, unless otherwise specified in this document.

When applicable, CAs operating under the OWGTM must respect the Wi-SUN Requirements.

### 4.1 Certificate Application

For CA Certificates, before issuing a new certificate for a subordinate Certification Authority OWGTM requires the fulfillment of a legally binding agreement between the affiliated organization and the OISTE Foundation, which includes the appropriate validation of the organization identity and signatories of the agreement. Additionally, for each Subordinate CA, it's required the fulfillment of a "CA Naming Request", which must be signed by authorized representative of the affiliate.

For subscriber certificates, the Registration Authorities operating under the OWGTM are competent and responsible for determining if the type of the requested certificate is adequate for the applicant and future subscriber, in conformity with the Certificate Policy related to that certificate, and therefore to proceed or not with the certificate application. The Certificate Application process must include a mean to express acceptance with the Subscriber Agreement, by means of a manuscript signature or another valid mechanism, and it's a first step to begin the certificate issuance process.

#### 4.1.1 Who can submit a certificate application

A certificate application can be submitted by the subject of the certificate or by an authorized representative of the subject.

#### 4.1.2 Enrollment process and responsibilities

WiSeKey is responsible for ensuring that the identity of each Certificate Applicant is verified in accordance with this CP and the applicable CPS prior to the issuance of a Certificate. Applicants are responsible for submitting sufficient information and documentation for the Issuer CA or the RA to perform the required verification of identity prior to issuing a Certificate.

This process includes the identification of suspicious or potentially dangerous requests, based on automated checks against the list of Manufacturers whose Wi-SUN Alliance membership has lapsed or whose enrolment rights have been suspended or withdrawn, against **hwType** values outside the Private Enterprise Number arc recorded for the Manufacturer, against **hwType** + **hwSerialNum** pairs already issued, and against previously denied requests marked as suspicious.

Enrolment additionally requires that the Manufacturer holds a current Proof of Wi-SUN Membership and a service agreement with WISEKey covering Wi-SUN IDevID issuance, as stated in section 9.1.

In particular and where applicable, CAs will respect the Wi-SUN Requirements.

## **4.2 Certificate application processing**

This section describes the procedures for processing certificate applications in the OWGTM Trust Model.

### **4.2.1 Performing identification and authentication functions**

Before issuing a certificate from the Root CA identified in Appendix B for a subordinate Certification Authority, it's required that two representatives of the PAA identify the CA Naming Application and the rightfulness to operate a subordinate CA under that Root.

The identification and authentication functions are delegated to the Registration Authorities operating under the OWGTM.

An authorized Registration Authority Officer will perform these functions. This role can be assumed by:

- An accredited person that, on behalf of a Registration Authority, personally executes the identification and authentication functions.
- An accredited software application that performs the identification and authentication functions for automated certification procedures. Automated registration is expressly permitted for Wi-SUN IDevIDs, where enrolment occurs in a manufacturing environment under a Manufacturer whose identity and identifiers have already been validated under sections 3.2.2 and 3.2.3. Any accredited software application will execute this function according to sections 3.2.2 and 3.2.3 of this document.

The steps to be executed by the Issuing CA or RA are as follows:

- As a first step, the Issuing CA or RA will perform the verifications stipulated in section 3.2.
- As a second step, the Issuing CA must verify the quality of the submitted public key: that it is a valid point on the NIST P-256 curve, that it is not the point at infinity, and that the same public key has not previously been certified by the Issuing CA.
- As a third step, the Issuing CA must check the certificate details against the certificates named in compromise notices published under section 4.9.1 and against rejected certificate requests, to identify suspicious certificate requests.

The Issuing CA can only issue a certificate after having successfully completed the above steps.

### **4.2.2 Approval or rejection of certificate applications**

An approval of a certificate application derives from the execution of the certificate issuance procedures, as defined in the section 4.3 of this document.

A rejection of a certificate application results in a notification being sent to the applicant by appropriate means and is registered for further reference.

### **4.2.3 Time to process certificate applications**

There is no time limit stipulated to complete the processing of an application.

## **4.3 Certificate issuance**

A certificate request will be forwarded to a Certification Authority for its issuance only after the Registration Authority confirms the correctness of the information contained in the request. The OWGTM is not responsible for monitoring, research or confirmation of the correctness of the information contained in a certificate during the intermediate period between its issuance and renewal, unless this period exceeds the re-verification limits stipulated in section 3.2.2 of this CP/CPS.

### **4.3.1 CA actions during certificate issuance**

A Certification Authority adhering to the OWGTM proceeds with the issuance of a certificate only after executing the necessary measures to verify that the signing request is authorized and genuine, as per the particular controls are stipulated in this document.

### 4.3.2 Notification to subscriber by the CA of issuance of certificate

For CA Certificates, OWGTM notifies directly to the authorized CA responsible.

WiSeKey will send, in general, all notifications to the subscriber using email to the address specified in the application process. These notifications should include a digital signature.

## 4.4 Certificate acceptance

Certificate acceptance is the final step in the certification issuance process. After Acceptance the certificate owner is entitled to use the certificate and issue valid digital signatures.

### 4.4.1 Conduct constituting certificate acceptance

For CA Certificates the CA representative must acknowledge the reception of the certificate, verifying that the Key Fingerprint matches the request. Installing the CA Certificate in the CA server constitutes tacit acceptance.

For Wi-SUN IDevIDs, acceptance occurs when the Manufacturer installs the certificate, its private key and the chain bundle into the device during manufacture. Because the certificate cannot subsequently be revoked or renewed, the Manufacturer SHALL verify the correctness of the `hwType` and `hwSerialNum` values before installation; after installation no correction is possible in the field.

For other certificate types, acceptance is understood after the subscriber or his representative performs one or more of the following: - Accepts the “Subscriber Agreement”, which includes the terms and conditions associated with the particular Certificate Policy, and which constitutes formal acceptance of those terms; or - Downloads and/or installs the certificate, making it technically available for usage; or - Doesn’t expressly refuse the certificate once the issuance notification has been sent.

### 4.4.2 Publication of the certificate by the CA

The CAs operating under the OWGTM publish issued CA certificates as specified in section 2 of this document. Wi-SUN IDevIDs are not published, as stated in section 2.3.

### 4.4.3 Notification of certificate issuance by the CA to other entities

The CA only notifies the Registration Authority from which it received the request of the issuance of a certificate. It is the RA’s duty to notify the certificate subscriber, as stipulated in section 4.3.2 of this CPS.

## 4.5 Key pair and certificate usage

The certificates issued by the OWGTM are used to provide authenticity, integrity, confidentiality and/or non-repudiation in electronic transactions and other computerized functions.

### 4.5.1 Subscriber private key and certificate usage

For CA Certificates the private key may only be used according to the CPS published by the subordinate CA, subject to approval by the OWGTM PAA.

The specific usages allowed for a private key associated to a certificate type issued in the OWGTM are as summarized in section 1.4 of this document

### 4.5.2 Relying party public key and certificate usage

Relying parties must access and use the public key and certificates issued under the OWGTM as stipulated in this CPS and as indicated in the “Relying Party Agreement” document, made public at the web page <http://www.oiste.org/repository>.

## 4.6 Certificate renewal

Certificate Renewal is understood as the issuance of a new certificate to a subscriber who maintains the key pair generated for the original certificate.

**Renewal is not applicable to Wi-SUN IDevIDs.** They carry no expiry date, so there is nothing to extend. The provisions of this section apply to CA certificates only.

### 4.6.1 Circumstance for certificate renewal

For CA Certificates, renewal is allowed for the purpose of modifying enhanced key usages, policy identifiers or other non-identity extensions. It is not available to extend a validity period, no certificate in this hierarchy having one, nor to modify name constraints, which are not used (section 7.1.5).

Renewal is not available for Wi-SUN IDevIDs, as stated in section 4.6.

### 4.6.2 Who may request renewal

The certificate renewal can be requested by the same entities allowed to request the first issuance of the certificate.

### 4.6.3 Processing certificate renewal requests

Certificate renewal requests are processed according to the same rules than the initial issuance.

### 4.6.4 Notification of new certificate issuance to subscriber

The notification of the issuance of a renewed certificate it will occur as described in section 4.3.2 of this document.

### 4.6.5 Conduct constituting acceptance of a renewal certificate

As stipulated in section 4.4.1 of this document.

### 4.6.6 Publication of the renewal certificate by the CA

The CAs operating under the OWGTM publish issued CA certificates as specified in section 2 of this document. Wi-SUN IDevIDs are not published, as stated in section 2.3.

### 4.6.7 Notification of certificate issuance by the CA to other entities

The CA only notifies the Registration Authority from which it received the request of the issuance of a certificate. It is the RA's duty to notify the certificate subscriber, as stipulated in section 4.3.2 of this document.

## 4.7 Certificate re-key

Certificate Re-Key is understood as the issuance of a new certificate to a subscriber that also generates a new key pair.

**Re-key is not applicable to Wi-SUN IDevIDs.** A Wi-SUN device receives its IDevID and key pair at manufacture and has no assured field mechanism for replacing either. Where a device must carry a different identity, a new IDevID is issued under the full procedures of section 3.2. The provisions of this section apply to CA certificates only.

### 4.7.1 Circumstance for certificate re-key

Any CA certificate that has not been retired can be re-keyed. Wi-SUN IDevIDs are not re-keyed, as stated above.

**4.7.2 Who may request certification of a new public key**

The certificate renewal can be requested by the same entities allowed to request the first issuance of the certificate.

**4.7.3 Processing certificate re-keying requests**

Certificate re-key requests are processed according to the same rules than the initial issuance.

**4.7.4 Notification of new certificate issuance to subscriber**

The notification of the issuance of a new certificate it will occur as described in section 4.3.2 of this document.

**4.7.5 Conduct constituting acceptance of a re-keyed certificate**

As stipulated in section 4.4.1 of this document.

**4.7.6 Publication of the re-keyed certificate by the CA**

The CAs operating under the OWGTM publish issued CA certificates as specified in section 2 of this document. Wi-SUN IDevIDs are not published, as stated in section 2.3.

**4.7.7 Notification of certificate issuance by the CA to other entities**

The CA only notifies the Registration Authority from which it received the request of the issuance of a certificate. It is the RA's duty to notify the certificate subscriber, as stipulated in section 4.3.2 of this document.

**4.8 Certificate modification**

The OWGTM does not allow the modification of certificates during their validity period. If the information contained in a certificate cease to be valid, or the circumstances of the subscriber change in such a manner that the conditions expressed in the CPS or the CP are not met, then the only accepted procedure is the issuance of a new certificate. For Wi-SUN IDevIDs the superseded certificate cannot be revoked and remains valid; the actions of section 4.9.1 apply instead.

**4.8.1 Circumstance for certificate modification**

No stipulation. Modification is not allowed.

**4.8.2 Who may request certificate modification**

No stipulation. Modification is not allowed.

**4.8.3 Processing certificate modification requests**

No stipulation. Modification is not allowed.

**4.8.4 Notification of new certificate issuance to subscriber**

No stipulation. Modification is not allowed.

**4.8.5 Conduct constituting acceptance of modified certificate**

No stipulation. Modification is not allowed.

**4.8.6 Publication of the modified certificate by the CA**

No stipulation. Modification is not allowed.

#### 4.8.7 Notification of certificate issuance by the CA to other entities

No stipulation. Modification is not allowed.

### 4.9 Certificate compromise handling, withdrawal and suspension

**Wi-SUN IDevIDs, and the CA certificates in their chain, are not subject to revocation.** This is a requirement of the Wi-SUN Requirements listed in Appendix D: such certificates never expire, carry no revocation pointers, and no revocation status service exists for them.

Exclusion of a device from a Wi-SUN FAN is therefore an **operational** matter for the network operator, performed through the access-control mechanisms of the Wi-SUN Requirements: the Authentication Server refuses to authenticate the node, and the Border Router rotates the group keys so that the excluded node cannot continue to participate. The Certification Authority plays no part in that exclusion and cannot effect it.

What the Certification Authority does instead, on the events listed below, is to cease issuance, notify, and publish. Those three actions replace revocation throughout this section.

Suspension of certificates is not supported.

#### 4.9.1 Circumstances for cessation of issuance and notification

All certificate subscribers receiving a digital certificate issued under a Root regulated by this CP/CPS must assume the stipulations contained in this section.

**4.9.1.1 Events affecting a Subscriber** The response is graduated. A compromise notice tells network operators to stop trusting certificates already in service, and that is a serious step which cannot be withdrawn once operators have acted on it. It is therefore reserved for events that actually cast doubt on issued certificates. Events that merely end a commercial relationship stop further issuance and are recorded, but do not tell operators to distrust devices already deployed.

**Group 1 — cease issuance and record.** On becoming aware of any of the following, a Certification Authority operating in the OWGTM SHALL cease issuing Wi-SUN IDevIDs for the affected Manufacturer, product model or device population, and record the event and its date in the Manufacturer's enrolment record. No compromise notice is published, and certificates already issued are unaffected:

1. The Subscriber requests in writing that the CA cease issuance, for example on discontinuing a product line;
2. The Manufacturer's Wi-SUN Alliance membership lapses or is withdrawn, or its entitlement to the Private Enterprise Number used in **hwType** ceases, without any indication that certificates already issued were wrongly issued.

**Group 2 — cease issuance, notify and publish.** On becoming aware of any of the following, a Certification Authority SHALL (a) cease issuing for the affected Manufacturer, product model or device population, (b) notify the Wi-SUN Alliance and every network operator known to the CA to be relying on the affected certificates, and (c) publish a compromise notice in the repository identified in section 2.1:

1. The Subscriber notifies the CA that the original certificate request was not authorized and does not retroactively grant authorization;
2. The CA obtains evidence that the Private Key of an issued Wi-SUN IDevID, or of a population of them, suffered a Key Compromise;
3. The CA is made aware of a demonstrated or proven method that can easily compute the Private Key from the Public Key in the certificate, or that the method used to generate the Private Key was flawed;
4. The CA obtains evidence that the validation of the Manufacturer identity, of its entitlement to the Private Enterprise Number, or of any device identifier included in the certificate, should not be relied upon;
5. The CA obtains evidence that a certificate was misused, or that the Subscriber has violated a material obligation of the Wi-SUN Subscriber Agreement;
6. The CA determines, or is made aware, that information in an issued certificate is inaccurate, or that the certificate was not issued in accordance with this CP/CPS.

Where the PAA so directs, an event in Group 1 is treated as an event in Group 2. Where a Group 1 event is later found to have concealed a Group 2 event, the Group 2 response follows on discovery.

A compromise notice identifies the affected certificates as precisely as the circumstances allow — by issuing CA, by **hwType**, by serial number range, or by individual serial number — and states the date from which operators should treat them as untrusted. It does not, and cannot, invalidate the certificates cryptographically.

**4.9.1.2 Retirement or termination of a Subordinate CA** A Wi-SUN Subordinate CA certificate cannot be revoked. Where any of the events below occurs, the Subordinate CA is **retired**: it ceases all issuance immediately, its private key is destroyed under section 6.2.10, a successor CA is established under section 5.6 where the service continues, and its identifiers are published so that network operators can remove the retired Subordinate CA certificate from the chain material held by the Authentication Server, or otherwise configure the server to reject chains that pass through it.

Two kinds of notice are published, and the distinction matters to an operator deciding what to do about devices already in service:

**Retirement notice** — the Subordinate CA stops issuing, and the certificates it has already issued are not called into question. An operator removes the retired CA from the chain material it holds once the devices concerned have been migrated or withdrawn, and need take no action against those devices in the meantime:

1. The Subordinate CA requests retirement in writing;
2. The Subordinate CA ceases operations for any reason;
3. The Subordinate CA reaches the issuance limit of section 6.3.2.

**Compromise notice** — the certificates issued by the Subordinate CA are called into question, and an operator should cease to accept chains through it:

1. The Issuing CA obtains evidence of Key Compromise of the Subordinate CA Private Key;
2. The Issuing CA obtains evidence that the Subordinate CA certificate was misused, or that the Subordinate CA has not complied with this CP/CPS or the applicable Certificate Policy;
3. The Issuing CA determines that information in the Subordinate CA certificate is inaccurate or misleading;
4. The Subordinate CA fails to submit a self-assessment when due, or refuses or obstructs an assessment, as stated in section 8.4.

Retirement required by the OISTE Foundation is accompanied by whichever notice the PAA directs.

Retirement of an **MCA** retires every MICA beneath it. Each such MICA ceases issuance and is listed in its own right in the notice and in Appendix B, because a network operator removing certificates acts on the certificates it actually holds, not on the hierarchy that produced them.

Because retirement is not cryptographically enforceable, the effectiveness of the measure depends on network operators acting on the published notice. Section 9.6.4 places that obligation on relying parties, and section 5.7.3 describes the procedure.

## 4.9.2 Who can request cessation of issuance

The certificate subscriber or its legal representative can request that the CA cease issuance for its own device population.

Third parties may report problems related to fraud, misuse, or compromise. Such reports must identify the entity making the report and specify the circumstances relied upon.

## 4.9.3 Procedure for a Certificate Problem Report

The procedure is detailed in the “Wi-SUN Subscriber Agreement”, published in the repository identified in section 2.1. Manufacturers enrolling and managing Wi-SUN IDevIDs through the INeS IoT Security Portal can submit a report through that same service.

To report suspected Private Key Compromise, Certificate misuse, Certificate mis-issuance, or any other type of fraud, compromise, misuse, inappropriate conduct or any other matter related to Certificates, the main and preferred method is sending an e-mail message to cps@wisekey.com.

For certificate subscribers that seek to obtain general support, the preferred method to communicate with WiSeKey is sending an e-mail message to support@wisekey.com.

#### 4.9.4 Grace period

There is no stipulation for grace periods. Investigation begins immediately upon receipt of a Certificate Problem Report by an authorized party.

#### 4.9.5 Time within which the CA must act

The CA begins investigating a Certificate Problem Report within 24 hours of receipt. Following that investigation, the CA acts within the following maximum periods:

| Action                                                                                                 | Applies to                  | Maximum period |
|--------------------------------------------------------------------------------------------------------|-----------------------------|----------------|
| Cease issuance for the affected Manufacturer, product model or device population                       | All events in section 4.9.1 | 24 hours       |
| Notify the Wi-SUN Alliance and every network operator known to be relying on the affected certificates | Group 2 events only         | 24 hours       |
| Publish the compromise notice in the repository                                                        | Group 2 events only         | 5 days         |
| Record the event in the Manufacturer's enrolment record                                                | Group 1 events              | 5 days         |
| Publish a retirement notice for a Subordinate CA                                                       | Section 4.9.1.2             | 5 days         |

Where a Wi-SUN Requirement stipulates a shorter period, that shorter period applies.

A Group 1 event carries no notification or publication obligation, as stated in section 4.9.1.1, because it does not call issued certificates into question.

#### 4.9.6 Obligations of relying parties

Because no revocation status is published for Wi-SUN IDevIDs or their chain, a relying party cannot discharge its obligations by consulting a CRL or an OCSP responder. Instead a relying party SHALL: - validate the certificate chain to the trust anchor it has provisioned, as stated in section 6.1.4; - obtain compromise and retirement notices from the repository identified in section 2.1, and apply them by removing the named Subordinate CA certificates from the chain material held by the Authentication Server, or otherwise configuring it to reject chains that pass through them; and - exclude a device that must no longer participate in the network by the access-control means of the Wi-SUN Requirements, namely refusal at the Authentication Server and group key rotation at the Border Router.

#### 4.9.7 CRL issuance frequency

Not applicable. No CRL is issued for Wi-SUN IDevIDs or for any CA certificate in their chain.

#### 4.9.8 Maximum latency for CRLs

Not applicable. No CRL is issued.

#### 4.9.9 On-line revocation/status checking availability

Not applicable. No on-line status checking service is offered, and the corresponding certificate extensions are prohibited by section 7.1.2.

#### 4.9.10 On-line revocation checking requirements

Not applicable. See section 4.9.6 for what is required of relying parties instead.

#### 4.9.11 Other forms of revocation advertisements available

The compromise and retirement notices described in section 4.9.1 are the only form of advertisement available, and they are advisory to relying parties rather than enforceable by cryptographic means.

#### 4.9.12 Special requirements re key compromise

Any party detecting a key compromise at any level in the OWGTM Trust Model is requested to immediately communicate it to a Registration or Certification Authority.

In particular for Wi-SUN certificates, Subscribers, Relying Parties, network operators and other third parties are requested to report any potential issue to the Certification Authority, including Certificate misuse and any other type of fraud, compromise or inappropriate conduct related to Certificates.

The appropriate methods to demonstrate key compromise are: - Create and sign a text file, - Create a custom CSR file, and/or - Send the private key, or a link to where it's publicly disclosed.

The main method for these communications is the one stipulated in section 4.9.3.

The response of the Certification Authority to a demonstrated key compromise is cessation of issuance, notification and publication under section 4.9.1. It is **not** revocation, which is not available. Subscribers and relying parties should understand that a compromised Wi-SUN IDevID remains cryptographically valid, and that the remedy lies in operator-side exclusion and, where the device population can be reached, in replacement of the affected devices.

#### 4.9.13 Circumstances for suspension

Suspension is not allowed for any certificate in scope of this CP/CPS.

#### 4.9.14 Who can request suspension

No stipulation. Suspension is not supported for any certificate in scope of this CP/CPS.

#### 4.9.15 Procedure for suspension request

No stipulation. Suspension is not supported for any certificate in scope of this CP/CPS.

#### 4.9.16 Limits on suspension period

No stipulation. Suspension is not supported for any certificate in scope of this CP/CPS.

### 4.10 Certificate status services

No certificate status service is offered for Wi-SUN IDevIDs or for the CA certificates in their chain, because those certificates are not subject to revocation and carry no status pointers. See section 4.9.

#### 4.10.1 Operational characteristics

The repository identified in section 2.1 publishes, over HTTP and without authentication or access restriction: - the Root CA and Subordinate CA certificates, and the chain bundles described in section 6.1.4; and - the compromise and retirement notices described in section 4.9.1.

These notices are the only status information the OWGTM publishes for the Wi-SUN hierarchy. They are advisory: a relying party must act on them, as stated in sections 4.9.6 and 9.6.4, because no cryptographic mechanism will do so on its behalf.

#### 4.10.2 Service availability

The repository is available on a 24x7 basis.

#### 4.10.3 Optional features

No stipulation.

### 4.11 End of subscription

Wi-SUN IDevIDs do not expire and are not revoked, so “End of Subscription” cannot be defined by the end of a certificate’s validity. It is understood instead to occur when the device reaches its end of life and is withdrawn from service, or when the Manufacturer ceases to be a Subscriber under section 4.9.1.1. The certificate remains cryptographically valid after that point; the obligations of the Manufacturer under section 9.6.3, and of relying parties under section 9.6.4, survive accordingly.

### 4.12 Key escrow and recovery

Key escrow is not permitted for Wi-SUN Certificates.

#### 4.12.1 Key escrow and recovery policy and practices

Not applicable. Key escrow is not offered for any certificate in scope of this CP/CPS.

#### 4.12.2 Session key encapsulation and recovery policy and practices

No stipulation.

## 5. FACILITY, MANAGEMENT, AND OPERATIONAL CONTROLS

This section describes the non-technical security controls used by the participants involved in the issuance, publishing and management of keys within the OWGTM. The OWGTM asserts the importance of these controls as a fundamental basis to provide trust to subscribers and all relying parties, and therefore establishes and maintains the necessary means to ensure and demonstrate that these controls are enforced.

These controls are under surveillance and audited both internally and externally by accredited bodies. The public manifests of these audits are published on a regular basis in the OWGTM web site (<http://www.oiste.org/repository>).

The OWGTM allows third parties to host and operate some of the components of its infrastructure. If such a delegation occurs, the assigned party will be requested to meet the controls stipulated in this section and an auditing process will be executed to ensure that the necessary measures to ensure these controls are effective are in place and enforced.

In particular: - The OISTE Foundation delegates the hosting and operations of the Root CA and the Wi-SUN Subordinate CAs (and related certificate publication services) to WISeKey. - The “Issuing CAs” (and related certificate publication and verification services) are hosted and operated by WISeKey (except for the cases of technically-constrained CAs, which could be hosted by their owners). These participants are allowed to delegate the hosting and operation to WISeKey only; other delegations or outsourcing are only permitted after a security assessment and a formal authorization. - Registration Authorities and Registration Authority Points are appointed by WISeKey. Registration Authorities are not allowed to delegate their operations to other parties without the approval and direct supervision of WISeKey.

### 5.1 Physical controls

This section describes the physical controls on facilities housing OWGTM components.

### **5.1.1 Site location and construction**

The OWGTM information systems are located in Secure Datacenters providing adequate security levels and under surveillance 24 hours a day, 7 days a week. These Datacenters are built in such a manner that relevant critical physical risks are managed.

### **5.1.2 Physical access**

The OWGTM Secure Datacenter implements diverse nested security perimeters. The access from an outer to an inner perimeter requires different security and authorization controls. Among these controls, biometric door access, video surveillance and intrusion detection systems are implemented.

### **5.1.3 Power and air conditioning**

The OWGTM Secure Datacenter implements power and air conditioning systems sufficiently dimensioned to accommodate the operating needs.

### **5.1.4 Water exposures**

The facilities are located in a place where natural flooding risks are controlled, and they are equipped with flooding sensors and alarms.

### **5.1.5 Fire prevention and protection**

The facilities implement fire detection, prevention and protection controls.

### **5.1.6 Media storage**

Sensible information media are stored securely in fireproof containers and high security safes, depending on the media type and the classification of the information they contain.

These containers and safes are located in redundant placements, in order to eliminate the risks of using a single location (i.e. in the case of fire or water damage).

Access to these storage locations and items is restricted to authorized persons and regulated by security procedures.

### **5.1.7 Waste disposal**

The disposal of optical or magnetic media and paper containing any information generated during OWGTM operations is executed following procedures established for such purposes, including demagnetization and/or destruction processes, depending on the media type to be disposed.

### **5.1.8 Off-site backup**

OWGTM executes a backup copy of all information needed to promote a secondary datacenter to operational status in the event of a disaster preventing the main datacenter from maintaining an adequate service level.

A remote backup copy is periodically made and stored in a way such that dual access control is required to restore the backup copies.

## **5.2 Procedural controls**

The information systems and services incorporated in the OWGTM are operated in a secure manner, following a set of predefined procedures that are enforced by the OWGTM and verified through periodical auditing activities.

For security reasons the information related to these controls are classified as “CONFIDENTIAL” and this document may only disclose a summarized version. Further detailed information is only disclosed to accredited auditors who are responsible for reviewing OWGTM components and operations.

### 5.2.1 Trusted roles

The OWGTM establishes and enforces a strict security policy to control all operations performed at any level of the Trust Model. This includes the identification and control of the Persons performing those operations. These Persons are considered “Trusted Roles” and include, but are not limited to: - Certification Authority Administrator - Certification Authority Operator - Registration Authority Administrator - Registration Authority Operator with Vetting attributions - Registration Authority Operator without Vetting attributions - Systems Administrator - Security Administrator - Policy Approval Authority Member

Persons seeking to become Trusted Persons by obtaining a Trusted Position must successfully complete the screening requirements set out in this CPS (section 5.3).

### 5.2.2 Number of persons required per task

The OWGTM establishes the need for the segregation of duties based on job responsibility in order to ensure that the adequate number of Trusted Persons is required to perform sensitive tasks.

The roles requiring separation of duties is stipulated in section 5.2.4.

### 5.2.3 Identification and authentication for each role

All the persons assuming a role in the OWGTM systems follow an authorization process that entitles them to access the appropriate information and systems for their role.

Physical access control for all the authorized persons accessing OWGTM’s systems and services systems is typically enforced using two factor authentication that usually includes biometrics.

### 5.2.4 Roles requiring separation of duties

Roles requiring Separation of duties include at least the following: - Any activity involved in the operation of a Root Certification Authority. - Enabling a CA into a production status (CA Ceremony procedures) - Issuance or retirement of CA Certificates - Validation of information and issuance of Wi-SUN Subordinate CA Certificates, and the authorisation of a Manufacturer to enrol Wi-SUN IDevIDs, including the configuration of the Private Enterprise Number arc constraint of section 7.1.5

## 5.3 Personnel controls

Personnel bearing one of the roles defined in section 5.2.1 will be required to fulfil the “OWGTM Trusted Professional Policy”, summarized in the following sections.

### 5.3.1 Qualifications, experience, and clearance requirements

Personnel acting directly or indirectly for the OWGTM will be required to possess the required qualification and/or proved experience in certification service provision environments. All involved personnel will be required to act according to the OWGTM Security Policy and to possess: - Knowledge and training (according to the role assigned to the person) in Public Key Infrastructures. - Knowledge and training (according to the role) in Information Systems Security. - Knowledge and training specific for the responsibilities assigned.

### 5.3.2 Background check procedures

The Human Resource Department conducts verification checks on permanent staff at the time of job applications, and ensures that all personnel with access to sensitive information are trustworthy and understand their responsibilities; this includes at a minimum the following: - Availability and verification of satisfactory references; - Confirmation of claimed academic and professional qualifications; - Identity checks of passport or similar document.

### 5.3.3 Training requirements

Personnel directly involved in OWGTM, including “Issuing CAs” operated by third parties and Registration Authorities, will follow an internal training plan adapted to their assigned attributions. This training will be compliant with industry regulations and with the Wi-SUN Requirements, as applicable.

### 5.3.4 Retraining frequency and requirements

Retraining sessions are required for all involved personnel in the case of environmental, technology and/or operative changes. Changes in practices and/or policies are communicated to all involved personnel.

### 5.3.5 Job rotation frequency and sequence

No stipulation.

### 5.3.6 Sanctions for unauthorized actions

If an unauthorized action is detected the OWGTM will undertake necessary disciplinary actions. Any action that (intentionally or unintentionally) contravenes the Certification Practice Statement.

Upon detection of an unauthorized action the OWGTM will initiate an investigation process. During this process the involved persons will be prevented from obtaining access to OWGTM systems and information.

Disciplinary actions will be taken after the investigation determines the severity and intent of the action.

### 5.3.7 Independent contractor requirements

External contractors are required to agree with the Information Security policies of the OWGTM and temporary staff not already covered by an existing confidentiality agreement shall also be required to sign the Non-Disclosure Agreement prior to being granted access to Information resources.

The agreement is reviewed when there are changes to employment terms or contracts.

### 5.3.8 Documentation supplied to personnel

All personnel incorporated within the OWGTM are provided access, as required for their role, to the following information: - Certification Practices Statement - Certificate Policies - Privacy Policy - Security Policy - Organization chart and assigned functions and responsibilities - Operational procedures - Incident response procedures

## 5.4 Audit logging procedures

This section describes the event logging and audit systems that have been implemented to maintain a secure environment in the OWGTM.

### 5.4.1 Types of events recorded

OWGTM records in their servers all events related to: - CA key lifecycle management events, including: 1. Key generation, backup, storage, recovery, archival, and destruction as captured by procedure documentation; and 2. Cryptographic device lifecycle management events as captured by procedure documentation. - CA and Subscriber Certificate lifecycle management events, limited to: 1. Certificate requests, issuance decisions and cessation-of-issuance decisions as captured by CA logs; 2. Verification activities 3. Date, time, phone number used, persons spoken to, and end results of verification telephone calls as captured by registration officers; 4. Acceptance and rejection of certificate requests as captured by CA logs; 5. Issuance of Certificates as captured by CA logs 6. Issuance of compromise and retirement notices under section 4.9.1, as captured by CA and repository logs - Security events, including: 1. Successful and unsuccessful PKI system access attempts as captured by operating system logs; 2. Major PKI and security system actions performed as captured by operational logs; 3. Security profile changes as captured by operating system logs; 4. System crashes, hardware failures, and other anomalies in server logs; 5. Entries to and exits from the CA facility as captured by access control logs. - Router and Firewall Activities Logs 1. Successful and unsuccessful login attempts to routers and firewalls; and 2. Logging of all administrative actions performed on routers and firewalls, including configuration changes, firmware updates, and access control modifications; and 3. Logging of all changes made to firewall rules, including additions, modifications, and deletions; and 4. Logging of all system events and errors, including hardware failures, software crashes, and system restarts.

#### **5.4.2 Frequency of processing log**

Logs are processed and audited when required.

For systems that are kept offline, as the Root CA, audit logs are only reviewed when an operation is executed.

#### **5.4.3 Retention period for audit log**

OWGTM and involved parties retain all audit logs as specified in section 5.5.2.

#### **5.4.4 Protection of audit log**

All audit records and archives are stored in fireproof cabinets only accessible for authorized persons.

The destruction of an audit record can only be executed after signed authorization from the OWGTM auditor and the OWGTM Information Security Manager. A trace of the destroyed materials is kept for future references.

#### **5.4.5 Audit log backup procedures**

The audit logs are backed up using incremental and remote procedures.

#### **5.4.6 Audit collection system (internal vs. external)**

The collection systems for audit logs in OWGTM is a combination of automatic and manual processes, and is executed by the appropriate operating systems, software applications, and personnel operating these systems.

#### **5.4.7 Notification to event-causing subject**

No stipulations.

#### **5.4.8 Vulnerability assessments**

OWGTM executes regular vulnerability assessment by monitoring the activity logs, at reasonable frequencies. In depth assessments and checks are performed on a yearly basis, including conformance to disaster recovery plans. In the event that an assessment could not be performed or was delayed, the OWGTM will inform the involved parties and records of such an event and its cause will be kept for future reference.

This security analysis implies the identification of necessary tasks to correct detected vulnerabilities.

### **5.5 Records archival**

This section includes the stipulations regarding record retention policies.

#### **5.5.1 Types of records archived**

The information and events archived are: - Information generated (at CA and RA) during the life cycle of all OWGTM certificates, - Contracts and agreements, - Audit logs stipulated in section 5.4 of this CPS.

#### **5.5.2 Retention period for archive**

Archived records and audit logs are retained for at least the period stated below.

Wi-SUN IDevIDs do not expire and are not revoked, so a retention period expressed as a term after expiry or revocation would never commence. For Wi-SUN certificates the CA therefore retains the records listed in section 5.5.1 for the operational life of the issuing Certification Authority, and for at least 7 years after that Certification Authority is retired under section 4.9.1.2.

#### **5.5.3 Protection of archive**

Access to archived materials is restricted to authorized persons, and controls to ensure the archive integrity are enforced.

#### **5.5.4 Archive backup procedures**

Daily backup copies are executed. The main copy is kept in the principal OWGTM facility and stored inside a secured zone. Copies are periodically stored offsite.

#### **5.5.5 Requirements for time-stamping of records**

In addition to stipulations in 5.5.3, a time stamp is included in the digitally signed records. The time stamp needs not be of cryptographic nature.

#### **5.5.6 Archive collection system (internal or external)**

Archive collection is an internal task in the OWGTM that cannot be outsourced to third parties.

The only exception are authorized Registration Authority points, which are allowed to archive information collected during the certificate life-cycle. In such case, this information must be kept securely, accessible only for authorized persons, and made available to any internal or external auditing entity mandated by OWGTM.

#### **5.5.7 Procedures to obtain and verify archive information**

Only authorized personnel obtain access to the physical media containing archives, backups and other recorded information.

Integrity checks are performed automatically if the archive includes a digital signature.

### **5.6 Key changeover**

OWGTM requires the creation of new keys for a CA needing to renew its certificate. Only in exceptional cases it can be accepted to repeat a CA Creation Ceremony maintaining the same keys created in a Hardware Security Module for a previous ceremony, in order to amend any error in the process.

In the Wi-SUN hierarchy no certificate expires, so key changeover is driven by the issuance limit of section 6.3.2 rather than by an approaching expiry date. A Wi-SUN Subordinate CA reaching that limit ceases issuing; a successor Subordinate CA is created with a fresh key pair, and Manufacturers served by the retired CA are enrolled under the successor. The retired CA certificate and the IDevIDs beneath it remain valid and require no action from relying parties.

### **5.7 Compromise and disaster recovery**

In the event that OWGTM systems and services are not available for a period greater than 12 hours, the Continuity Plan will be activated. This Continuity Plan seeks to ensure that the critical services (as stated in section 5.7.4) are available in less than 72 hours after the plan is activated.

The following sections summarize specific situations and the stipulated reaction in OWGTM. The detailed Continuity Plan is a confidential document.

#### **5.7.1 Incident and compromise handling procedures**

The Certification and/or Registration Authorities operating under the OWGTM are required to enforce the necessary controls to ensure and demonstrate that the Incident and Compromise Handling Procedures are effective. Involved people must be conveniently trained in their roles and responsibilities in the execution of their duties.

The following subsections disclose the procedures executed in such these events.

#### **5.7.2 Computing resources, software, and/or data are corrupted**

If the hardware or software resources are altered or suspected to have been altered, the OWGTM will stop normal operations until a secure environment is established. In parallel, an audit will be conducted in order to identify the cause and stipulate the necessary actions to avoid future iterations.

In the event digital certificates are issued during the uncertainty period and a risk exists that these certificates could be compromised, the OWGTM will identify the affected certificates, notify the subscribers, and act under section 4.9.1. Wi-SUN IDevIDs issued in that period cannot be revoked; the notice identifies them so that network operators can exclude the affected devices.

### 5.7.3 Entity private key compromise procedures

This section is the one a Wi-SUN network operator should read first, because the usual remedy is unavailable: a compromised CA private key in the Wi-SUN hierarchy **cannot be contained by revoking its certificate**. Every certificate it has issued remains cryptographically valid, and every certificate in the chain lacks the extensions a relying party would use to learn otherwise.

Where a private key is compromised, or suspected to be compromised, in the Wi-SUN hierarchy, the following are executed in addition to the stipulations of section 5.7.2:

1. **Cease issuance immediately.** The affected Certification Authority stops issuing, within the deadline of section 4.9.5.
2. **Destroy the key.** The compromised private key is destroyed under section 6.2.10, under dual control and with a recorded trace, so that it cannot be used again by the OWGTM even inadvertently.
3. **Notify.** The Wi-SUN Alliance, the PAA, every Manufacturer served by the affected Certification Authority, and every network operator known to the OWGTM to rely on the affected certificates are notified within the deadline of section 4.9.5.
4. **Publish.** A notice is published in the repository identified in section 2.1, identifying the affected Certification Authority by subject name, Subject Key Identifier and certificate fingerprint, and identifying the affected end-entity population as precisely as the circumstances allow. Because operators anchor on the Root CA and not on the Subordinate CA, the notice states that operators should remove the retired Subordinate CA certificate from the chain material held by the Authentication Server, or otherwise configure the server to reject chains that pass through it. Where the affected Certification Authority is the Root CA itself, the notice states that the Root CA certificate must be removed from the trust store.
5. **Re-establish the service.** Where the service continues, a successor Certification Authority is created under section 5.6, and Manufacturers are re-enrolled under it. Devices already carrying an IDevID from the compromised Certification Authority are not re-certified in the field; their replacement is a matter between the Manufacturer and the network operator.

If the compromised key is the Root CA key, the trust anchor itself must be replaced. Every relying party has to provision the successor Root CA certificate into its Authentication Servers and Border Routers, and every device manufactured thereafter carries a chain to the new anchor. Devices already in the field cannot be migrated by the Certification Authority. The OWGTM states this plainly so that the consequence is understood before it is relied upon: the security of the Wi-SUN hierarchy rests on preventing Root CA key compromise, not on recovering from it.

### 5.7.4 Business continuity capabilities after a disaster

In the event of a disaster (independently of its nature) that affects OWGTM's main facilities, and any services that are provided from these, the OWGTM Service Continuity Plan will be activated, ensuring that the services identified as "Critical" are available in less than 72 hours after the Plan activation. The rest of services would be available in the reasonable terms, as judged adequate for their importance and criticality level.

## 5.8 CA or RA termination

The causes that could imply the termination of a Certification or Registration Authority operating under the OWGTM are: - Private Key Compromise - A political or judicial decision - A Contract Termination after a breach of the corresponding Terms and Conditions

In the case a Certification Authority under OWGTM is forced to terminate its activities, the minimum actions to be executed are: - Immediately after there's a Termination decision, notify all certificate subscribers, the Wi-SUN Alliance, and every network operator known to rely on the affected certificates. - Cease all issuance, and destroy the Certification Authority private key under section 6.2.10. The certificates already

issued **cannot be revoked** and remain cryptographically valid; termination does not invalidate them. - Inform all relying parties that have a registered direct relationship with that Certification Authority about the termination of the certificate service provision. This will also terminate the accreditation granted to the Certification Authority to operate under OWGTM. - Publish a notice of the termination in the repository identified in section 2.1, identifying the terminated Certification Authority by subject name, Subject Key Identifier and certificate fingerprint, so that network operators can remove the retired Subordinate CA certificate from the chain material held by the Authentication Server, or otherwise configure the server to reject chains that pass through it, and undertake other public communications as deemed necessary to inform the wider relying party community.

In the case an OWGTM Root Certification Authority is terminated, this will imply the termination of the entire hierarchy dependent of that Root CA.

## 6. TECHNICAL SECURITY CONTROLS

This section describes the measures taken by Certification Authorities operating under the OWGTM. The OWGTM believes these controls are fundamental to provide trust to subscribers and all relying parties, and has therefore established the necessary means to ensure and demonstrate that these controls are enforced. These controls are under surveillance and audited both internally and externally by accredited bodies. The public manifests of these audits are published on a regular basis in the web site (<http://www.oiste.org/repository>).

### 6.1 Key pair generation and installation

Under the OWGTM, Key Pairs are generated under the necessary security levels and always occurring in secure physical facilities and under the adequate personnel control.

#### 6.1.1 Key pair generation

Key Pairs of Certification Authorities operating in the OWGTM are generated and installed under a procedure compliant with applicable regulations. Main details of this procedure are: - The Root Certification Authority key creation ceremony is audited by an external qualified auditor. - Subordinated Certification Authorities are generated under direct supervision of internal auditors from WISeKey. - CA Ceremonies are executed by designated trusted personnel. - There's a pre-defined execution script that must be followed during the Ceremony. - During the Ceremony, enough audit track is recorded in order to proof that the Ceremony was executed as planned and without any security risk. - After the Ceremony, a Ceremony Report is generated and properly archived for future reference. Key pairs for the Root Certification Authorities in the OWGTM are generated in hardware security modules (HSM) accredited under the standards specified in section 6.2.1.

Key pairs for the Policy and Issuing Certification Authorities in the OWGTM may be generated in hardware security modules (HSM) accredited under the standards specified in section 6.2.1.

Key pairs for Subordinate Certification Authorities in the OWGTM may be generated in escrowable form, protected under dual control and split-knowledge at all times, and imported and operated within hardware security modules (HSM) under the standards specified in section 6.2.1.

For Subscriber Certificates, unless otherwise noted in this CPS, Subscriber is solely responsible for the generation of the Key Pair appropriate to the Certificate type being applied for.

#### 6.1.2 Private key delivery to subscriber

Private keys corresponding to CA certificates are generated inside the CA cryptographic module and are never delivered to any subscriber.

If the specific subscriber certificate type allows the generation of the private key by the Registration Authority, the usage of password-protected encrypted software files, or smart-cards or other valid crypto-tokens is accepted.

### 6.1.3 Public key delivery to certificate issuer

Public keys of CA certificates are delivered to relying parties within the CA certificate itself, as described in section 6.1.4.

Public keys generated by, or for, the end-entities are sent to the Certification Authority through secure channels using the OWGTM Registration Authorities, as part of a certificate request in acceptable formats, such as PKCS#10 or other standard CSR format.

### 6.1.4 CA public key delivery to relying parties

The public keys of all Certification Authorities operating under the OWGTM Trust Model are included in the corresponding certificate and published and can be freely downloaded from its repository which is located at <http://www.oiste.org/repository>.

The Wi-SUN Root CA certificate is not distributed through any public trust store. It is delivered in two directions, and the OWGTM supports both:

- **To Manufacturers**, as a chain bundle containing every CA certificate between the IDevID and the Root CA — the issuing MICA, the MCA where the three-tier shape is used — together with the Root CA certificate. The Manufacturer provisions this bundle into the device at manufacture, together with the IDevID and its private key, because a Wi-SUN node presents only its own certificate during EAP-TLS and must hold the remainder of the chain locally.
- **To network operators**, for installation in the trust store of the Authentication Server and in the Border Router, so that an IDevID presented by a node can be validated to the anchor.
- **To other Manufacturers and integrators**, for provisioning into devices that must perform node-to-node pairwise authentication with devices certified under this CP/CPS.

On that last point the OWGTM states its position plainly. The Root CA identified in Appendix B is not cross-certified by any Wi-SUN Alliance root. A device certified under a different Wi-SUN PKI can therefore authenticate a peer certified under this one only if it has been provisioned with this Root CA certificate as a trust anchor. The OWGTM publishes the certificate for exactly that purpose and will supply it to any party that asks, but it makes **no representation** that devices certified under other PKIs are, or will be, so provisioned. A Manufacturer or operator that depends on cross-PKI node-to-node authentication should confirm the trust anchors provisioned in the device populations concerned before deployment.

Both are obtained from the repository identified in section 2.1. The integrity of a trust anchor obtained from the repository **MUST** be verified against the SHA-256 fingerprint and Subject Key Identifier published in Appendix B before it is installed. This verification is the only protection available: because the hierarchy publishes no revocation information, an operator that installs the wrong anchor has no mechanism that will later correct it.

### 6.1.5 Key sizes

Every certificate in the Wi-SUN hierarchy, at every tier, carries an elliptic-curve key on the NIST P-256 curve (secp256r1 / prime256v1), with the public key in uncompressed point format. The Root CA identified in Appendix B holds such a key.

SHA-256 is the only permitted hash. P-384, RSA and SHA-1 **SHALL NOT** be used anywhere in the Wi-SUN hierarchy.

This uniformity is required by the Wi-SUN Requirements, so that a constrained FAN node can validate a chain with a single curve and a single hash implementation. It is narrower than the algorithm set the OWGTM permits elsewhere, and the narrower rule prevails here.

### 6.1.6 Public key parameters generation and quality checking

The algorithm used in the Wi-SUN hierarchy for key generation is ECDSA over the NIST P-256 curve. Key pairs are generated by a validated random source within the cryptographic module.

The CA rejects any submitted public key that fails the quality checks of section 4.2.1, namely that the key is a point on the P-256 curve, is not the point at infinity, and has not previously been seen by the CA in another certificate request.

#### 6.1.7 Key usage purposes (as per X.509 v3 key usage field)

Key usage for Wi-SUN CA certificates is restricted to certificate signing (`keyCertSign`). `cRLSign` is not asserted, because no CRL is issued anywhere in this hierarchy.

A Wi-SUN IDevID asserts `digitalSignature`, and MAY additionally assert `keyAgreement`. Its extended key usage MUST contain `id-kp-wisun-fan-device` (1.3.6.1.4.1.45605.1) and `id-kp-clientAuth`.

All subscriber certificates issued in the OWGTM contain the “KEY USAGE” and “EXTENDED KEY USAGE” attributes, as defined by the X.509v3 standard. More information is available in section 7 of this document.

## 6.2 Private Key Protection and Cryptographic Module Engineering Controls

The OWGTM has established controls to ensure that the risks derived from a private key compromise are managed and kept under reasonable levels. These controls are different for the main components (Certification Authorities) and end subscriber keys.

### 6.2.1 Cryptographic module standards and controls

Certification Authorities in the OWGTM are required to use Hardware Security Modules certified at least to FIPS 140-2 (or FIPS 140-3) Level 3 for CA key protection, and at least Level 2 for other PKI components. Common Criteria certification against a protection profile of equivalent assurance is also accepted.

### 6.2.2 Private key (n out of m) multi-person control

Private keys for Certification Authorities are always under multi-person control. Activation data needed to enable a Certification Authority will be shared in such a way that at least two authorized persons are needed to perform any sensitive operation on a Certification Authority, except where unattended operational restart of Issuing CAs is enabled.

Private keys for end-entities are under the sole control of the subscriber or authorized representative.

### 6.2.3 Private key escrow

Not applicable. Private key escrow is not provided for any certificate in scope of this CP/CPS, as stated in section 4.12.

### 6.2.4 Private key backup

Backup copies of CA private keys for all Certification Authorities under the OWGTM Trust Model are kept for routine recovery and disaster recovery purposes. Such keys are always stored in encrypted form within hardware cryptographic modules and associated key storage devices. Cryptographic modules used for CA private key storage meet the requirements of this CPS.

Private key backup for end-user subscribers, if supported for a certain certificate type, it would be implemented as described in section 4.12.

### 6.2.5 Private key archival

The CA shall not provide key archival services to subscribers. Private keys of retired CAs are destroyed under section 6.2.10 rather than archived, since a retired CA certificate remains valid and its key must not remain usable.

### 6.2.6 Private key transfer into or from a cryptographic module

For Certification Authorities operating under the OWGTM Trust Model it is mandatory that key pairs are operated in Hardware Security Modules as defined in section 6.2.1. Private Keys can be transferred to adequate hardware security modules for back-up and recovery operations.

There's no stipulation for Keys belonging to other PKI participants.

### 6.2.7 Private key storage on cryptographic module

CA or RA private keys held on hardware cryptographic modules are stored in an encrypted form supported by the HSM vendor.

Private keys of Wi-SUN IDevIDs are generated and held in a hardware-backed key store (secure element, secure enclave or TPM) that prevents export of the private key in plaintext. Where a device cannot provide such a key store, the key must be held in an encrypted container and this limitation must be recorded by the Manufacturer and accepted by the PAA.

### 6.2.8 Method of activating private key

The private key in Certification Authorities in the OWGTM is activated by initiating the PKI Software and activating the HSM where the key is stored. This process requires at least a dual-person control, except for Issuing CAs where automatic key activation in case of system failure or restart is allowed.

The activation of Subscriber's private key is stipulated in section 6.4.

### 6.2.9 Method of deactivating private key

The private key in Certification Authorities is deactivated by shutting-down the associated server or by terminating the PKI software or by extracting or shutting-down the HSM that contains the key. This task can be done by a System Administrator and, when planned, has to be notified and authorized to/from the CA Responsible.

Deactivating RA or other end-user private keys based in hardware is performed by the extraction of the secure device (smart-card or other accepted crypto-tokens) from the workstation it is used.

Deactivating of other end-user subscriber private keys, while not based in hardware, is accomplished by shutting down the device where the private key is stored. The subscriber must take all reasonable measures to avoid unauthorized use of the device.

### 6.2.10 Method of destroying private key

The procedure to destroy a private key is initiated in the following cases: - Private Key is no longer used and it's mandated its destruction - The token or HSM containing the key has deteriorated to an extent that prevents normal usage - A lost or stolen token is found, and the keys it contained are suspected to be compromised

A private key can be destroyed by the key owner or a legal representative. In such cases the corresponding certificate cannot be revoked; a notice is published under section 4.9.1 and the community is notified. The procedure used to destroy the private key depends on the particular container holding it, being responsibility of the individual executing the destruction doing it in an appropriate way. In particular, for private keys associated to CAs, this task must be executed under dual control and appropriate tracking information must be recorded.

### 6.2.11 Cryptographic Module Rating

No stipulation additional to section 6.2.1.

## 6.3 Other aspects of key pair management

This section includes additional stipulations regarding key pair management.

### 6.3.1 Public key archival

Because no certificate in the Wi-SUN hierarchy expires or is revoked, public keys are archived for the period stated in section 5.5.2: the operational life of the issuing Certification Authority, and at least 7 years after it is retired.

### 6.3.2 Certificate operational periods and key pair usage periods

The fully operational period for a certificate starts at issuance. No certificate in a Wi-SUN IDevID chain has a defined end to that period: none expires, and none is revoked.

| Certificate Type                   | Validity Period                                                                             |
|------------------------------------|---------------------------------------------------------------------------------------------|
| Root CA (identified in Appendix B) | No scheduled expiration. <b>notAfter</b> = 31 December 9999, 23:59:59 UTC (99991231235959Z) |
| Wi-SUN Subordinate CA              | No scheduled expiration. <b>notAfter</b> = 99991231235959Z                                  |
| Wi-SUN IDevID                      | No scheduled expiration. <b>notAfter</b> = 99991231235959Z                                  |

This is not a choice of the OWGTM. The Wi-SUN Requirements listed in Appendix D mandate that every certificate in an IDevID chain carries **notAfter** = 99991231235959Z, the RFC 5280 encoding for a certificate with no well-defined expiry. A Wi-SUN FAN node may be installed in infrastructure with a service life measured in decades, has no assured route to certificate renewal in the field, and must be able to authenticate for as long as it operates.

Two consequences follow, and they are stated here because they govern the rest of this document: - **Renewal and re-key do not apply** to Wi-SUN IDevIDs (sections 4.6 and 4.7). A device that needs a different identity receives a new IDevID by a new issuance, not a renewal. - **A key cannot be retired by letting its certificate lapse.** A Subordinate CA is retired by the procedure of section 4.9.1.2, and a compromised key by the procedure of section 5.7.3. Both depend on notification and publication rather than on expiry or revocation.

To bound the exposure that follows from an unbounded certificate lifetime, the OWGTM limits the period during which a **Subordinate CA key may be used to issue**: a Wi-SUN Subordinate CA SHALL cease issuing 10 years after its certificate was issued, at either tier, and a successor SHALL be established under section 5.6. The limit applies to an MCA in respect of the MICAs it certifies, and to a MICA in respect of the IDevIDs it issues. The retired certificate remains valid, and the certificates issued beneath it remain valid, but no further certificates are issued under that key.

The certificates are operational for signature validation from issuance to the end of the archival period stated in 6.3.1.

## 6.4 Activation data

This section stipulates the management of the data necessary to activate the private keys.

### 6.4.1 Activation data generation and installation

Activation data for Certification Authorities are generated and stored in cryptographic tokens and/or smart cards and are only used by authorized persons. In addition, these tokens require a password or PIN in order to enable the activation process.

Activations requiring a multi-person control will be enforced by splitting the activation data in several tokens.

For Wi-SUN IDevIDs, the private key is generated inside the device secure element or equivalent hardware key store, or injected in a controlled manufacturing environment. In either case: - The key store must enforce access control such that the private key can only be used by the device firmware for the purposes stated in section 1.4.1. - Where keys are injected in a factory, the injection environment must be physically and logically controlled by the Manufacturer, key material must be transported encrypted, and any copy held

outside the device must be destroyed once injection is confirmed. - No shared or default activation secret may be used across devices.

Private Keys for Registration Authority operator certificates, if protected in a hardware device, require the usage of a password or PIN code of eight or more characters in order to activate the device where the key is stored.

#### **6.4.2 Activation data protection**

Only the authorized persons know the password or PIN to activate the private keys. In the case of end-entities, only the certificate subscriber is entitled to know this information.

In all cases, the owner of the activation data is required to safeguard the secrecy of this information.

#### **6.4.3 Other aspects of activation data**

No stipulation.

### **6.5 Computer security controls**

The details of this information are classified and therefore not made public. The documents describing Computer Security Controls are only available for the people involved in the OWGTM and only disclosed to accredited external parties for auditing purposes.

Certification and Registration Authorities operating under the OWGTM Trust Model are required to meet these Security Controls. The compliance is periodically enforced by an auditing procedure.

#### **6.5.1 Specific computer security technical requirements**

OWGTM enforces the use of the appropriate procedures and technical measures and systems in order to effectively control security risks. These include, but not limited to: - Strong password policies - Constant improvement of administration and operating procedures - Physical isolation of confidential systems - Antivirus and anti-malware detection systems - Periodic internal security reviews

#### **6.5.2 Computer security rating**

OWGTM establishes the computer ratings to be met by the Certifications and Registration Authorities operating under the Trust Model. Compliance with these ratings is ensured by periodic internal audits.

### **6.6 Life cycle technical controls**

This information is classified and is therefore not disclosed in detail. The detailed documents are available for review by external auditors after the appropriate authorization process.

#### **6.6.1 System development controls**

Systems are developed using the WISeKey KeySteps Methodology, which ensures the security and quality by setting a series of policies and operational and technical procedures controlling the building of the PKI components during all the phases of the project.

Authenticity and integrity of critical software components must be checked before they are enabled in a production environment, by using code signing or other acceptable methods.

#### **6.6.2 Security management controls**

The OWGTM recommends following the ISO27000 security management approach. In particular WISeKey, as main operator of the Trust Model follows an informal adoption of such security standards.

#### **6.6.3 Life cycle security controls**

Life cycle and change-related security controls are ensured by the WISeKey KeySteps Methodology.

## 6.7 Network security controls

The OWGTM enforces the adoption of effective controls to minimize any risk related to Network Security. The detailed information about these controls is classified and only made available for external auditors after the appropriate authorization process.

In particular, the server used for the OWGTM Root CA are off-line systems, physically disconnected from any computer network, and all communication of sensitive information is protected using encryption and digital signature techniques.

## 6.8 Time-stamping

No stipulation.

# 7. CERTIFICATE PROFILES

All certificates issued under the OWGTM are compliant to: - ITU-T Recommendation X.509 (1997): Information Technology - Open Systems Interconnection - The Directory: Authentication Framework, June 1997 - RFC 5280: Internet X.509 Public Key Infrastructure Certificate and CRL Profile, April 2002 (“RFC 5280”). - RFC 5480: Elliptic Curve Cryptography Subject Public Key Information, March 2009. - RFC 4108: Using CMS to Protect Firmware Packages, August 2005, for the **id-on-hardwareModule** other name form. - IEEE 802.1AR: Secure Device Identity, for the concept of an Initial Device Identifier (IDevID).

In addition, every certificate in a Wi-SUN IDevID chain conforms to the Wi-SUN Requirements listed in Appendix D, which for the profile below means sections 6.5.1 and 6.5.1.1 of the Wi-SUN FAN Technical Profile Specification. Where this section and an adopted Wi-SUN Requirement differ, the Wi-SUN Requirement prevails.

## 7.1 Certificate profile

The OWGTM defines different certificate profiles corresponding to the allowed certificate types issued under the different hierarchies.

The general certificate profiles are: - Wi-SUN Root CA Certificate: self-signed trust anchor of the Wi-SUN hierarchy. - Wi-SUN Manufacturer CA (MCA) Certificate: subordinate to the Root CA; issues MICA certificates and never issues end-entity certificates. - Wi-SUN Manufacturer Issuing CA (MICA) Certificate: issues Wi-SUN IDevIDs. - Wi-SUN IDevID: identifies an individual Wi-SUN device.

Where this document refers to a **Wi-SUN Subordinate CA** without qualification, the term covers both the MCA and the MICA tiers.

Two chain shapes are permitted, and a Manufacturer may be served by either:

| Shape      | Chain                         | Certificates in the chain |
|------------|-------------------------------|---------------------------|
| Two-tier   | Root CA → MICA → IDevID       | 3                         |
| Three-tier | Root CA → MCA → MICA → IDevID | 4                         |

The three-tier shape suits a Manufacturer that wants a branded Certification Authority of its own beneath which several issuing CAs operate, for example one per production site or product family. Neither shape may be extended: the Wi-SUN Requirements limit a chain to four certificates including the Root CA and the IDevID, and the **pathLenConstraint** values stated in section 7.1.2 hold every chain within that limit. An MCA SHALL NOT be issued beneath another MCA; that rule is enforced by configuration under section 7.1.5 rather than by the certificate, and is tested at each assessment under section 8.4.

The different profiles are mainly differentiated by the appropriate combination of values in the “Key Usage”, “Extended Key Usage” and/or the use of particular Policy Identifiers.

The OWGTM must ensure that the certificate profiles are aligned with this section and with any applicable Wi-SUN Requirement.

### 7.1.1 Version number(s)

All certificates in the OWGTM conform to X.509 Version 3.

### 7.1.2 Certificate extensions

The following extensions are used in the Wi-SUN hierarchy. Any extension not listed is not included. The profile restates the requirements of the Wi-SUN FAN Technical Profile Specification sections 6.5.1 and 6.5.1.1, as adopted in Appendix D.

**Root CA Certificate** (existing certificate, identified in Appendix B)

| Extension            | Critical | Value                                   |
|----------------------|----------|-----------------------------------------|
| basicConstraints     | Yes      | cA = TRUE, no<br>pathLenConstraint      |
| keyUsage             | Yes      | keyCertSign                             |
| subjectKeyIdentifier | No       | 73:3C:14:C9:31:9B:53:C5:1F:E2:D8:55:3A: |

The Root CA certificate was issued on 6 March 2025, the day after this CP/CPS took effect, and under it. This profile records the certificate as issued. It satisfies the chain requirements of the Wi-SUN Requirements: a P-256 key, an ecdsa-with-SHA256 signature and a notAfter value of 99991231235959Z. It asserts **keyCertSign** alone: neither **cRLSign** nor **digitalSignature** is present, consistent with a hierarchy that issues no CRL. It carries no **authorityKeyIdentifier** extension.

### Wi-SUN Manufacturer CA (MCA) Certificate

| Extension              | Critical | Value                                                                   |
|------------------------|----------|-------------------------------------------------------------------------|
| basicConstraints       | Yes      | cA = TRUE,<br><b>pathLenConstraint = 1</b>                              |
| keyUsage               | Yes      | keyCertSign                                                             |
| certificatePolicies    | No       | 2.16.756.5.14.8.4.2                                                     |
| subjectKeyIdentifier   | No       | Hash of the public key                                                  |
| authorityKeyIdentifier | No       | keyIdentifier field only, carrying<br>the key identifier of the Root CA |

**pathLenConstraint = 1** permits at most one further CA certificate beneath the MCA, which holds any chain through an MCA to four certificates and so within the limit of the Wi-SUN Requirements. It does not by itself distinguish what that subordinate CA is used for: the rule that the certificate beneath an MCA is a MICA, and never another MCA, is a policy rule enforced by the configuration constraint of section 7.1.5 and verified at assessment under section 8.4, not by this extension.

### Wi-SUN Manufacturer Issuing CA (MICA) Certificate

| Extension              | Critical | Value                                                                                                                                                               |
|------------------------|----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| basicConstraints       | Yes      | cA = TRUE,<br><b>pathLenConstraint = 0</b>                                                                                                                          |
| keyUsage               | Yes      | keyCertSign                                                                                                                                                         |
| certificatePolicies    | No       | 2.16.756.5.14.8.4.3                                                                                                                                                 |
| subjectKeyIdentifier   | No       | Hash of the public key                                                                                                                                              |
| authorityKeyIdentifier | No       | keyIdentifier field only, carrying<br>the key identifier of the issuing<br>CA, which is the Root CA in the<br>two-tier shape and the MCA in<br>the three-tier shape |

`pathLenConstraint = 0` permits no further CA certificate beneath the MICA: it may issue end-entity certificates only.

Neither an MCA nor a MICA certificate SHALL contain a `cRLDistributionPoints` extension, nor an `authorityInfoAccess` extension with an `id-ad-ocsp` access method, because no certificate in a Wi-SUN IDevID chain is subject to revocation (see section 4.9). `cRLSign` is not asserted at either tier, as neither issues a CRL.

### Wi-SUN IDevID

| Field or extension                                         | Critical   | Value                                                                                                                              |
|------------------------------------------------------------|------------|------------------------------------------------------------------------------------------------------------------------------------|
| <code>version</code>                                       | —          | v3                                                                                                                                 |
| <code>serialNumber</code>                                  | —          | Unique within the issuing CA, as stated in section 3.1.5                                                                           |
| <code>signature</code>                                     | —          | ecdsa-with-SHA256, matching the outer <code>signatureAlgorithm</code>                                                              |
| <code>issuer</code>                                        | —          | Copied from the subject of the issuing Wi-SUN Subordinate CA                                                                       |
| <code>notBefore</code>                                     | —          | Time of issuance, UTC                                                                                                              |
| <code>notAfter</code>                                      | —          | 99991231235959Z<br>(GeneralizedTime)                                                                                               |
| <code>subject</code>                                       | —          | Empty. The device identity is carried in <code>subjectAltName</code>                                                               |
| <code>subjectPublicKeyInfo</code>                          | —          | <code>id-ecPublicKey</code> , <code>secp256r1</code> , uncompressed point (RFC 5480)                                               |
| <code>issuerUniqueID</code> , <code>subjectUniqueID</code> | —          | Absent                                                                                                                             |
| <code>basicConstraints</code>                              | No         | Absent, or present with <code>cA = FALSE</code>                                                                                    |
| <code>keyUsage</code>                                      | Yes        | <code>digitalSignature</code> ; <code>keyAgreement</code><br>MAY additionally be asserted                                          |
| <code>extKeyUsage</code>                                   | No         | <code>id-kp-wisun-fan-device</code><br>(1.3.6.1.4.1.45605.1) and<br><code>id-kp-clientAuth</code> (1.3.6.1.5.5.7.3.2)              |
| <code>subjectAltName</code>                                | <b>Yes</b> | Exactly one <code>otherName</code> of type <code>id-on-hardwareModuleName</code> (1.3.6.1.5.5.7.8.4), as detailed in section 7.1.4 |
| <code>authorityKeyIdentifier</code>                        | No         | <code>keyIdentifier</code> field only                                                                                              |
| <code>subjectKeyIdentifier</code>                          | No         | Optional; hash of the public key where present                                                                                     |
| <code>certificatePolicies</code>                           | No         | 2.16.756.5.14.8.4.4                                                                                                                |

A Wi-SUN IDevID SHALL NOT contain a `cRLDistributionPoints` extension, nor an `authorityInfoAccess` extension of any kind. Revocation extensions are prohibited by the Wi-SUN Requirements; the `caIssuers` access method is omitted because the complete chain, including the Root CA certificate, is provisioned into the device at manufacture as stated in section 6.1.4, and because the certificate is carried in EAP-TLS over a constrained radio link where size matters.

The `subjectAltName` extension is marked critical. Because the subject is empty, a relying party that cannot process the extension must reject the certificate rather than treat it as unnamed.

An empty subject is permitted by RFC 5280 section 4.1.2.6 precisely on the condition satisfied here, that `subjectAltName` is present and critical. Some Authentication Server products have nonetheless handled empty-subject client certificates poorly. Operators should confirm that their Authentication Server accepts a client certificate with an empty subject, a critical `subjectAltName` and a `notAfter` value of 99991231235959Z before deploying a device population, since none of those can be changed afterwards.

### 7.1.3 Algorithm object identifiers

The Wi-SUN hierarchy uses ECDSA over NIST P-256 exclusively, at every tier.

| Certificate                     | Signature algorithm (applied by its issuer) | Subject public key                                     |
|---------------------------------|---------------------------------------------|--------------------------------------------------------|
| Root CA (existing, self-signed) | ecdsa-with-SHA256<br>(1.2.840.10045.4.3.2)  | id-ecPublicKey on prime256v1 / secp256r1 (NIST P-256)  |
| Wi-SUN MCA and MICA             | ecdsa-with-SHA256<br>(1.2.840.10045.4.3.2)  | id-ecPublicKey on secp256r1                            |
| Wi-SUN IDevID                   | ecdsa-with-SHA256<br>(1.2.840.10045.4.3.2)  | id-ecPublicKey on secp256r1, uncompressed point format |

No other curve, signature algorithm or hash is permitted anywhere in a Wi-SUN IDevID chain. In particular P-384, RSA and SHA-1 SHALL NOT be used. This is a requirement of the Wi-SUN Requirements and not a choice of the OWGTM, and it is the reason the algorithm agility otherwise allowed in the OWGTM does not apply here.

### 7.1.4 Name forms

**CA certificates.** The Subject Name combines appropriate values of `commonName`, `organizationName` and `countryName` to form an identifier that uniquely identifies the CA and distinguishes it from other CAs in the Trust Model.

**Wi-SUN IDevIDs.** The subject field is empty. A Wi-SUN device is identified by a single `otherName` entry in the critical `subjectAltName` extension, of type `id-on-hardwareModuleName` (1.3.6.1.5.5.7.8.4), whose `HardwareModuleName` structure is composed as follows:

| Component                | Content                                                                                                                                                                                                                                                                                                                                               |
|--------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <code>hwType</code>      | An OBJECT IDENTIFIER beneath the IANA Private Enterprise Number (PEN) arc of the Manufacturer, of the form <code>1.3.6.1.4.1.&lt;PEN&gt;.&lt;subtypes&gt;</code> , where the subtypes identify the product model and, where the Manufacturer chooses, its hardware version. The Manufacturer's entitlement to the PEN is verified under section 3.2.2 |
| <code>hwSerialNum</code> | An OCTET STRING carrying the serial number of the individual device, unique within the <code>hwType</code> value, taken from the Manufacturer's production record under section 3.2.3                                                                                                                                                                 |

Further `subjectAltName` entries MAY be present but are ignored for Wi-SUN path validation and SHALL NOT be relied upon. The OWGTM does not include any.

**Certificate serial numbers.** The `serialNumber` of a Wi-SUN IDevID is generated from a random source within the issuing cryptographic module and contains at least 12 octets of entropy. Sequential serial numbers, although permitted by the Wi-SUN Requirements, are not used by the OWGTM, because a random serial is simpler to warrant as unique across the manufacturing volumes concerned.

### 7.1.5 Name constraints

The Root CA identified in Appendix B does not assert name constraints.

The `nameConstraints` extension is **not used** anywhere in the Wi-SUN hierarchy. It cannot serve its purpose here: a Wi-SUN IDevID has an empty subject, so a `directoryName` constraint has nothing to act on, and RFC 5280 defines no constraint form for the `otherName` that actually carries the identity.

A Wi-SUN Subordinate CA operated by a Manufacturer is instead **technically constrained by configuration**, at whichever tier it occupies: - a **MICA** is configured to issue only IDevIDs whose **hwType** lies beneath the IANA Private Enterprise Number arc assigned to that Manufacturer, and to reject any request outside that arc; - an **MCA** is configured to certify only MICAs belonging to that same Manufacturer, and never to certify a further MCA. The **pathLenConstraint** of section 7.1.2 bounds the depth of any resulting chain, but neither part of this rule is expressed in the certificate; both are configuration.

These constraints are not expressed in the certificate in a form a relying party can evaluate, and are therefore not enforceable by one. They are verified instead: - at accreditation, before the Subordinate CA Certificate is issued, under section 3.2.2; and - at every assessment under section 8.4, which tests the configuration against a request outside the permitted arc.

Subordinate CAs operated by WISKey are configured with the same constraints for each Manufacturer they serve, at whichever tier they occupy.

#### 7.1.6 Certificate policy object identifier

An object identifier (OID) is a unique number that identifies an object or policy. The OIDs are administered by the OWGTM and listed in the Appendix C, “OID Inventory”.

#### 7.1.7 Usage of Policy Constraints extension

No stipulation.

#### 7.1.8 Policy qualifiers syntax and semantics

Unless disallowed by the applicable requirements, certificates may contain information in the Certificate Policy extension.

#### 7.1.9 Processing semantics for the critical Certificate Policies extension

The “Certificate Policy” extension identifies the Policy that the OWGTM assigned explicitly with a certificate policy. Software Applications requiring a specific certificate profile to process a digital signature must check this extension in order to verify the suitability of the certificate for the intended purpose.

### 7.2 CRL profile

Not applicable. No Certificate Revocation List is issued for Wi-SUN IDevIDs or for any CA certificate in their chain, because those certificates are not subject to revocation. See section 4.9.

### 7.3 OCSP profile

Not applicable. No OCSP responder is operated for the Wi-SUN hierarchy, and the corresponding extension is prohibited in the certificate profile of section 7.1.2.

## 8. COMPLIANCE AUDIT AND OTHER ASSESSMENTS

OWGTM monitors and ensures compliance to legal, security and industry requirements, in all levels of the Trust Model, through internal and external audits.

### 8.1 Frequency or circumstances of assessment

Every Certification Authority operating under a Root regulated by this CP/CPS, and every dependent Registration Authority, SHALL provide the PAA with a self-assessment against this CP/CPS: - **Initially**, before the CA is enabled for production issuance. No Subordinate CA Certificate is issued, and no Registration Authority is accredited, until the initial self-assessment has been submitted to and accepted by the PAA. - **Annually** thereafter, within twelve months of the previous self-assessment.

The OWGTM, for its part, is bound to audit any participant seeking to operate under its Roots. The PAA will conduct, or commission, an assessment of any such participant before admission and whenever it considers it necessary thereafter, and the participant is contractually obliged to submit to that assessment and to grant the access required to perform it.

The detailed internal audit scheme — the assessment criteria, the reporting format and the qualification of the assessors — will be defined by the PAA and published in a future revision of this document. Until it is published, self-assessments are performed against the provisions of this CP/CPS as a whole.

## 8.2 Identity/qualifications of assessor

The assessor will be selected when an audit or assessment is required. Any company or professional whose services are contracted as auditor or assessor will be required to fulfil these requirements: - Adequate and demonstrable capability and experience in PKI audit and information security assessment. - Independence from the operational management of the entity being assessed. The assessor reports to the PAA and not to the audited CA or RA.

A self-assessment under section 8.1 is prepared by the assessed entity itself, and must be signed by a person empowered to bind that entity.

Assessment is performed against this CP/CPS by the PAA, or by an assessor it appoints, and the resulting Audit Statement Report is published as stated in section 8.6. The qualification criteria for appointed assessors will be set out in the internal audit scheme announced in section 8.1.

The Wi-SUN Alliance approves the Certification Authorities permitted to issue Wi-SUN IDevIDs but does not evaluate or audit them. It likewise provides no policy or procedure evaluation of a Certification Authority operated by a Manufacturer, treating that as a matter between the Manufacturer and its own customers. The assessments described in this section are therefore the sole assurance offered as to the practices of the Certification Authorities operating under this CP/CPS, including the manufacturer-operated Subordinate CAs admitted under section 8.4.

## 8.3 Assessor's relationship to assessed entity

The OWGTM audit policy does not allow any kind of legal, organizational or other relationship with the external auditor that would result in a conflict of interests.

## 8.4 Topics covered by assessment

The OWGTM establishes the need for audit and accreditation of the following: - The Root CA and the Subordinate CAs owned or operated by WISEKey. These services are assessed as stated in sections 8.1 and 8.2. - Subordinate CAs owned and/or operated by Manufacturers or other third parties, and Registration Authorities. These services must meet the practices stipulated in this CP/CPS and the certificate policies they are entitled to issue under. A manufacturer-operated Subordinate CA is admitted only after the initial self-assessment of section 8.1 has been accepted and the OWGTM has completed its own accreditation assessment of the participant.

Because the Private Enterprise Number constraint of section 7.1.5 is enforced by configuration rather than by a certificate extension, every assessment of a Subordinate CA SHALL include a functional test of that constraint, appropriate to its tier: - for a **MICA**, the assessor submits an enrolment request carrying a **hwType** outside the Manufacturer's recorded arc and confirms that it is rejected; - for an **MCA**, the assessor submits a request to certify a Subordinate CA that does not belong to that Manufacturer and confirms that it is rejected.

The result is recorded in the assessment report.

A participant that fails to submit a self-assessment when due, or that refuses or obstructs an assessment conducted or commissioned by the PAA, is in breach of this CP/CPS. The PAA may suspend its issuance rights under section 8.5 and, where the breach is not remedied, the Subordinate CA is retired under section 4.9.1.2.

## 8.5 Actions taken as a result of deficiency

In the case a deficiency is identified, the OWGTM will adopt and will be responsible for all necessary corrective measures.

In the case of a severe deficiency affecting the reliable operation of a Certification or a Registration Authority, the OWGTM could decide to temporarily suspend the activities of the affected systems or services until the deficiency is solved.

## 8.6 Communication of results

All assessment results will be conformed as: - Detailed Report. This document includes all the topics covered by the executed assessment program in detail. The detailed report is deemed private and only available to the following parties: - Certification Authority owner - OWGTM Policy Approval Authority - The Wi-SUN Alliance, upon reasoned request - Audit Statement Report. This document only includes a formal statement from the auditor and reflects the result of the assessment, listing the topics covered and a global result. The summarized report is deemed public and is only published in the OWGTM and Issuing Repository.

# 9. OTHER BUSINESS AND LEGAL MATTERS

This section includes the stipulations for business and legal matters and should be understood as having a contractual value by all the PKI participants.

## 9.1 Fees

The fees applicable to the Certification Services covered by this CPS can be subject to variation according to specific agreement with the participants in the service. The detailed information of the fees is made available for the subscribers or other affected parties before enabling such services.

For Wi-SUN IDevIDs the commercial sequence is fixed by the Wi-SUN programme and precedes any issuance: the Manufacturer obtains its Proof of Wi-SUN Membership from the Alliance; an account is established with WISKey and a service agreement is negotiated, which specifies the means by which certificate requests and issued certificates are exchanged and, where applicable, the creation of a dedicated Subordinate CA; the Manufacturer places a purchase order; WISKey invoices; and certificates are issued once payment is made. A Manufacturer may hold more than one account, and a single service agreement may cover several of them.

### 9.1.1 Certificate issuance or renewal fees

The issuance of certificates in the OWGTM is considered a commercial service and therefore subject to fees. The fees depend on the certificate and project and are agreed before making it available to subscribers.

### 9.1.2 Certificate access fees

OWGTM doesn't enforce stipulations for certificate access fees. In general, any participant shouldn't apply fees on the access to certificate information made public in the different repositories.

### 9.1.3 Revocation or status information access fees

OWGTM doesn't enforce stipulations for revocation or status information access fees. In general, the Issuing CA shouldn't apply fees on the access to certificate information made public in the different repositories.

### 9.1.4 Fees for other services

The operators of Issuing CAs in the OWGTM can set fees for different commercial services provided to parties willing to participate in the Trust Model. This includes, but not limited to: - Managed PKI Services - CA Signing Services - CA Hosting and operation services

### 9.1.5 Refund policy

The refund policy applicable to commercial services provided by WISEKey is included in the “Subscriber agreement” and/or general Terms and Conditions communicated to the end-user when providing the service. Other refund policies can be established and, in such cases, must be effectively communicated to all affected parties.

## 9.2 Financial responsibility

The OWGTM established the adequate controls to ensure that the different levels of financial responsibility are met by the different participants, according to their impact in the trust model.

### 9.2.1 Insurance coverage

For the Root CA, Issuing CAs and the certification services provided directly by WISEKey, it is maintained an Errors and Omissions insurance policy that covers the liability expressed in section 9.8. For affiliates and corporate customers acting as Certification or Registration Authorities, the contractual terms agreed among the parties ensure the assumed responsibilities for each party and transfer the requirement for appropriate insurance for the transferred liabilities.

### 9.2.2 Other assets

No stipulation.

### 9.2.3 Insurance or warranty coverage for end-entities

The maximum liability per subscriber certificate issued under the OWGTM is to be established in the applicable Subscriber Agreement published by the Issuing CA.

## 9.3 Confidentiality of business information

In general, an Issuing CA under the OWGTM may not disclose the confidential information of a subscriber, or use that information for any purpose, except: - To its staff requiring the information for the purposes of this CPS or for delivery of the services. - With the explicit consent of the subscriber. - If required to do so by any law, or an applicable agreement.

### 9.3.1 Scope of confidential information

Information released to subscriber(s) or relying parties by Issuing CA may be considered confidential.

All Issuing CA under the OWGTM shall keep the following types of information confidential and maintains reasonable controls to prevent the exposure of such records to non-trusted personnel. - All private keys - Any activation data used to access private keys or gain access to the CA system - Any business continuity, incident response, contingency, and disaster recovery plans - Any other security practices, measures, mechanisms, plans, or procedures used to protect the confidentiality, integrity or availability of information - Any information held by the Issuing CA in accordance with Section 9.4 - Any transactional, audit log and archive record identified in Section 5.4 or 5.5, including certificate application records and documentation submitted in support of certificate applications whether successful or rejected. - Transaction records, financial audit records and external or internal audit trail records and any audit reports (with the exception of an auditor’s letter confirming the effectiveness of the controls set forth in this CPS) - All information classified explicitly as “PRIVATE”, “CONFIDENTIAL” or “STRICTLY CONFIDENTIAL” when generated or exchanged among involved parties.

### 9.3.2 Information not within the scope of confidential information

The following information shall be deemed as non-confidential: - All information contained in the issued certificates and Certificate Revocation Lists (CRLs) including all information that can be derived from such. - All information classified expressly as “PUBLIC”.

### 9.3.3 Responsibility to protect confidential information

The OWGTM Issuing CAs are responsible of the protection of the confidential information generated or communicated during all operations. Delegated parties, as the entities managing subordinate Issuing CAs or Registration Authorities, are responsible for protecting confidential information that has been generated or stored by their own means.

For end entities, the certificate subscribers are responsible to protect their own private key and all activation information (i.e. passwords or PIN) needed to access or use the private key.

## 9.4 Privacy of personal information

The Issuing CAs operating in the OWGTM must publish their own Privacy Policy and communicate it adequately to the certificate subscribers. This Policy must be compliant with the applicable requirements for international commercial services, and specifically with the Wi-SUN Requirements and the European General Data Protection Regulation (GDPR).

Wi-SUN IDevIDs contain no personal data. The subject field is empty, and the hardware module name identifies a manufactured device, not a person. Personal data processed under this CP/CPS is limited to the contact details of the natural persons who act for a Manufacturer during enrolment.

In general, it must be understood that the CAs act as a “Data Controller” and the RAs and other parties involved in certificate management are “Data Processors” or, in certain occasions, “Joint Controllers”.

### 9.4.1 Privacy plan

WiSeKey publishes the Privacy Policy and other related materials in <https://www.wisekey.com/repository>.

### 9.4.2 Information treated as private

Personal information about an individual that is not publicly available in the contents of a certificate or CRL is considered private.

### 9.4.3 Information not deemed private

For personal information the provisions of section 9.3.2 apply respectively.

### 9.4.4 Responsibility to protect private information

The OWGTM ensures the compliance of the legal obligations for Certification Authorities, Registration Authorities and other entities operating under the OWGTM Trust Model. Each of these participants is responsible to protect the private information that has been provided by subscribers or other participants in the issuance and maintenance of digital certificates.

### 9.4.5 Notice and consent to use private information

In order to perform the certification provisioning service, the Issuing CAs and other parties interacting with certificate subscribers are required to obtain the consent to use the subscriber’s personal information.

This consent is understood by the explicit acceptance of the “Wi-SUN Subscriber Agreement” by the Manufacturer during the certificate request process. This acceptance is recognized by the subscriber’s acceptance to obtain and install the certificate.

### 9.4.6 Disclosure pursuant to judicial or administrative process

The participants in the OWGTM will disclose personal information of the participants if required by a judicial or administrative process, upon presentation of appropriate orders in accordance with the Applicable Laws of the country where the Certification Authority operates.

### 9.4.7 Other information disclosure circumstances

No stipulation.

## 9.5 Intellectual property rights

All Intellectual Property rights, including the digital certificates and CRLs issued by the OWGTM Root CAs, Object Identifiers, this CPS and the different CP are owned by the OISTE Foundation.

The private and public keys are the property of their respective owners.

Any commercial or protected trademark included in the Distinguished Name of a certificate is under responsibility of the certificate subscriber.

## 9.6 Representations and warranties

This section includes general stipulations, specific terms can be stipulated in the appropriate Certificate Policy for a given certificate type and users community. If such is the case, specific Subscriber, Relying Party and other agreements will be distributed among the parties.

### 9.6.1 CA representations and warranties

OWGTM Root CAs will: - Establish a chain of trust by issuing a certificate, which is a self-signed certificate - Ensure that the Root signs any subordinate CAs issued under the OWGTM hierarchy - Properly conduct the verification process described in section 3.2 - Ensure the accuracy and completeness of any part of the certificate information which is generated or compiled by the OWGTM, according to the applicable Certification Policy - Ensure that all relevant information concerning a certificate is recorded (electronically or otherwise) for an appropriate period of time, and in particular, for the purpose of providing evidence for the purposes of legal proceedings - Utilize trustworthy systems, procedures and human resources in performing its services - Comply with any other relevant provisions of the relevant CP or CPS, and other approved documents.

All CAs in the OWGTM will: - Operate according to the requirements of this CPS and any applicable SLA. - Ensure at the time it issues a certificate, that the certificate contains all the elements required by the CP or PDS. - Manage their keys in accordance with Section 6.2 Private Key Protection and Cryptographic Module Engineering Controls. - Ensure the availability of a Certificate Directory and CRL - Promptly revoke a certificate if required. - In particular, CAs warrant that every certificate they issue in a Wi-SUN IDevID chain conforms to the certificate profile of section 7.1, and thereby to the Wi-SUN Requirements adopted in Appendix D. - CAs do **not** warrant that an issued certificate can be revoked, suspended or invalidated, because no such mechanism exists in this hierarchy. The remedies available to the CA are those stated in section 4.9.

### 9.6.2 RA representations and warranties

The Registration Authorities operating under the OWGTM warrant that: - Will operate according to the requirements of this CPS. - Their Certificates meet all material requirements of this CPS. - No errors have been introduced in the Certificate information by the entities approving the Certificate Application as a result of a failure when managing the Certificate Application. - There are no material misrepresentations of fact in the Certificate at the entities approving the Certificate Application or issuing the Certificate. - Availability of revocation services (when applicable) and use of a repository conforming with the applicable CPS in all material aspects.

Registration Authority commercial contracts and agreements could include additional warranties.

### 9.6.3 Subscriber representations and warranties

The Subscribers of certificates issued under the OWGTM must warrant that: - All information supplied by the Subscriber and contained in the Certificate is true and valid. - All representations made by the Subscriber in the submitted Certificate Application are true and valid. - His or her private key is protected and that no unauthorized person has ever had access to the Subscriber's private key. - An obligation and warranty that it will not install and use the Certificate(s) until it has reviewed and verified the accuracy of the data in each Certificate. - An obligation and warranty to install the Certificate and its associated Private Key only in the device that the Certificate identifies, and to use the Certificate solely in compliance with all applicable laws, solely for authorized company business, and solely in accordance with the Subscriber Agreement. - The

Certificate is being used exclusively for authorized and legal purposes, consistent with this CPS. - Each digital signature created using the private key corresponding to the public key listed in the Certificate is the digital signature of the Subscriber, and the Certificate has been accepted at the time the digital signature is created. - The Subscriber is an end-user Subscriber and not a CA, and is not using the private key corresponding to any public key listed in the Certificate for purposes of digitally signing any Certificate (or any other format of certified public key), as a CA or otherwise. - An obligation and warranty to promptly cease using a Certificate and its associated Private Key, and to submit a Certificate Problem Report under section 4.9.3, in the event that: (a) any information in the Certificate is or becomes incorrect or inaccurate, or (b) there is any actual or suspected misuse or compromise of the Subscriber's Private Key associated with the Public Key listed in the Certificate. The Subscriber is on notice that the Certification Authority cannot revoke the Certificate in response.

In addition, and because a Wi-SUN IDevID can neither expire nor be revoked, a Manufacturer subscribing to Wi-SUN IDevIDs warrants that: - each **hwSerialNum** it submits is unique within its **hwType** and identifies a single physical device; - each **hwType** it submits lies beneath an IANA Private Enterprise Number to which it is entitled, and it will notify the CA immediately if that entitlement ceases; - the private key of each device is generated within, or injected into, protected hardware key storage that prevents export of the key in plaintext, and the device is hardened so that the key cannot be extracted through the interfaces the device exposes. This is a contractual obligation under this CP/CPS, and not merely the recommendation made by the Wi-SUN Requirements, precisely because a compromised key cannot be remedied by revocation; - the manufacturing process in which certificates and keys are installed is physically and logically secured against the injection of keys or identifiers into unauthorised devices; - it will submit a Certificate Problem Report under section 4.9.3 without delay on becoming aware of a key compromise, a duplicated identifier or a mis-issuance; and - it will verify, before deploying a device population, that its own equipment and any Authentication Server it controls accept a **notAfter** value of 99991231235959Z and a certificate with an empty subject and a critical subjectAltName; and - it understands and accepts that the Certification Authority cannot revoke an issued Wi-SUN IDevID, that exclusion of a device from a network is the responsibility of the network operator, and that the practical remedy for a compromised device population is its replacement.

The "Wi-SUN Subscriber Agreement" could include additional warranties.

#### 9.6.4 Relying party representations and warranties

Before relying on a certificate or a digital signature, relying parties must: - Validate the certificate and the certificate chain to the trust anchor they have provisioned under section 6.1.4, having first verified that anchor against the fingerprint published in Appendix B. - Ascertain and comply with the purposes for which the certificate was issued and any other limitations on reliance or use of the certificate that are specified in this CPS.

For Wi-SUN IDevIDs, a relying party cannot check revocation or expiry, because neither exists. The following obligations take the place of that check, and a relying party that does not discharge them has no basis for reliance: - obtain the compromise and retirement notices published in the repository identified in section 2.1, on a schedule proportionate to the risk it carries, and apply them to its Authentication Server trust store and its admission decisions; - exclude a device that must no longer participate in the network by the access-control means of the Wi-SUN Requirements, namely refusal at the Authentication Server and group key rotation at the Border Router; and - treat the presence of a valid chain as evidence of the device's identity at the time of manufacture only, and not as evidence that the device remains uncompromised.

If a relying party relies on a digital signature, or certificate, in circumstances where it has not been validated, it assumes all risks with regard to it (except those that would have arisen had the relying party validated the certificate), and is not entitled to any presumption that the digital signature is effective as the signature of the subscriber or that the certificate is valid.

Relying parties must also comply with any other relevant obligations specified in this CPS including those imposed on the entity when it is acting as a subscriber.

Additionally, the relying party should consider the certificate type. The final decision concerning whether or not to rely on a verified digital signature is exclusively that of the relying party.

The "Relying party agreement" could include additional warranties.

### 9.6.5 Representations and warranties of other participants

No stipulation.

## 9.7 Disclaimers of warranties

Other Disclaimer of warranties (if existing) is included as part of the agreement presented to each PKI participant, or included in other documents published by the Issuing CA.

For the avoidance of doubt, the Wi-SUN Alliance gives no warranty in respect of the Certification Authorities operating under this CP/CPS. The Alliance approves such Certification Authorities and requires Manufacturers to hold membership, but it does not audit them, provides no policy or procedure evaluation of manufacturer-operated Certification Authorities, and is not responsible for their security. No statement in this CP/CPS, and no approval granted by the Alliance, should be read as a warranty by the Alliance.

## 9.8 Limitations of liability

Liability limitations are regulated in the contractual agreement between the concerned parties. If applicable such concepts are specified in the Subscriber, Relying Party or other commercial agreements made among the participants.

Subject to the foregoing limitations, OWGTM's aggregate liability limit towards all End users, Relying Parties and any other entities that are not Subordinate PKI Entities towards all persons with regard to certificates issued by the Root CA is CHF 5,000,000.00 (Five Million Swiss Francs), with a maximum aggregate per year liability on such certificates of CHF 500,000.00 (Five Hundred and Thousand Swiss Francs).

The certificates issued under this CP/CPS neither expire nor can be revoked, so the period over which claims may arise is not bounded by a certificate validity period as it is elsewhere in the OWGTM. These limits are carried over unchanged from the general OWGTM provisions and are subject to legal review before this CP/CPS is published. The OISTE Foundation delegates in WISeKey, as lead operator, this liability, according to a formal agreement executed between the parties, and that WISeKey ensures via an appropriate "Errors and Omissions" insurance.

## 9.9 Indemnities

Indemnities are regulated in the contractual agreement between the concerned parties. If applicable such concepts are specified in the CPS published in the Subscriber, Relying Party or other commercial agreements made among the participants.

## 9.10 Term and termination

This section refers to the times and validity periods related to this document.

### 9.10.1 Term

This Document becomes effective once published in the OWGTM Repository.

### 9.10.2 Termination

This Document (at the current version) is valid until replaced by a new version.

### 9.10.3 Effect of termination and survival

The Certificates issued during the validity period of the version of this document are bound to the clauses hereby included until the expiration of these certificates.

The termination of the CP/CPS shall be without prejudice to the responsibility to protect confidential and personal information.

## 9.11 Individual notices and communications with participants

Notices to subscribers must be sent to the physical, postal, facsimile or email address of the subscriber, which is included in its registration information, or to another address that the subscriber has specified to the sender. Reasonable measures to ensure the reception of the notices are taken.

## 9.12 Amendments

The OWGTM can unilaterally amend this document, by attaining adhering to the following procedure: - The modification needs to be justified under legal and technical considerations. - Any modification in the CPS cannot contradict the stipulations in the related CP, and vice-versa. - There is a modification procedure and change management for these amendments. - Any implications to the participants due to such amendments will be conveniently notified.

### 9.12.1 Procedure for amendment

The entity with the authority to make and approve any change in the CPS and the related CP in the OWGTM is the Policy Approval Authority (PAA, described in section 1.5 of this document), which reviews the change request, assesses whether the change request is required, and approves the changes.

A change can only be made to the approved documents once approval has been granted by the PAA.

On the assumption that the PAA decides to modify the CPS or a particular CP, a new version of the document will be generated. The version of the document (exposed in all the pages of the document) is controlled with two numbers separated by a period. The first number (major version) is incremented if the new version could affect the acceptance of the certificates by the users. The second number (minor version) is incremented if the amendment is not considered to affect the certificate acceptance criteria. The version numbers are not encoded in the OID identifying the document, which is stable across versions as stated in Appendix C.

Once a new version of the document is approved, the procedures stipulated in section 9.12.2 will be executed.

### 9.12.2 Notification mechanism and period

Any modification in this document will be published in the OWGTM website (<http://www.oiste.org/repository>) and affected participants will be directly notified if necessary.

In particular, it is not considered necessary to directly notify participants of “minor version” changes of the documents.

In the case of a change in the “major version” of a document, the OWGTM may notify the affected participants with a digitally signed electronic message.

### 9.12.3 Circumstances under which OID must be changed

The OID identifying this CP/CPS does not change between versions of the document.

The OID identifying a Certificate Policy is changed only where the change in policy is such that certificates already issued under the previous OID could no longer be considered to have been issued under the new one. In that case a new OID is allocated from the arc in Appendix C and the previous OID is retired, not reused.

## 9.13 Dispute resolution provisions

As agreed between the parties by the acceptance of Subscriber and/or Relying Party agreements. If no prior agreement was made to the dispute resolution mechanism, general rules of law shall apply.

## 9.14 Governing law

The CP, the CPS and the operations of the OWGTM are all governed by the laws of Geneva, Switzerland.

## 9.15 Compliance with applicable law

All related parties shall comply with all applicable Swiss laws, rules, regulations, ordinances, and directives, and all provisions required thereby to be included in this CPS are hereby incorporated herein by reference.

Applicable national laws can affect parties operating Certification Authorities in different jurisdictions.

## 9.16 Miscellaneous provisions

This section includes miscellaneous contractual and legal clauses.

### 9.16.1 Entire agreement

All provisions made in this CPs and the associated CP apply to all Certification and Registration Authorities operating under the OWGTM and its subscribers.

Agreements or supplementary agreements by word of mouth are not allowed.

### 9.16.2 Assignment

Parties to this CPS may not assign any of their rights or obligations under this CPS or applicable agreements without the written consent of WISEKey.

### 9.16.3 Severability

Should individual provisions of this CPS prove to be ineffective or incomplete, this shall be without prejudice to the effectiveness of all other provisions.

The ineffective provision will be replaced by an effective provision deemed as most closely reflecting the sense and purpose of the ineffective provision. In the case of incomplete provisions, amendment will be agreed as deemed to correspond to what would have reasonably been agreed upon in line with the sense and purposes of this CPS, had the matter been considered beforehand.

### 9.16.4 Enforcement (attorneys' fees and waiver of rights)

No stipulation.

### 9.16.5 Force Majeure

Force Majeure clauses, if existing, are included in the "Subscriber Agreement".

## 9.17 Other provisions

No stipulation.

# Appendix A: Glossary

## Acronyms

| Acronym | Description                                                   |
|---------|---------------------------------------------------------------|
| AAA     | Authentication, Authorization and Accounting                  |
| CA      | Certificate Authority or Certification Authority              |
| CP      | Certificate Policy                                            |
| CPS     | Certification Practice Statement                              |
| CRL     | Certificate Revocation List                                   |
| CSR     | Certificate Signing Request                                   |
| DevID   | Secure Device Identifier, as defined by IEEE 802.1AR          |
| EAP-TLS | Extensible Authentication Protocol – Transport Layer Security |

| Acronym | Description                                                                          |
|---------|--------------------------------------------------------------------------------------|
| ECDSA   | Elliptic Curve Digital Signature Algorithm                                           |
| FAN     | Field Area Network                                                                   |
| FIPS    | (US Government) Federal Information Processing Standard                              |
| GDPR    | General Data Protection Regulation (European Union)                                  |
| HSM     | Hardware Security Module                                                             |
| HTTP    | Hypertext Transfer Protocol                                                          |
| IDevID  | Initial Device Identifier, as defined by IEEE 802.1AR                                |
| IEEE    | Institute of Electrical and Electronics Engineers                                    |
| IETF    | Internet Engineering Task Force                                                      |
| ITU     | International Telecommunication Union                                                |
| LDevID  | Locally Significant Device Identifier, as defined by IEEE 802.1AR                    |
| NIST    | National Institute of Standards and Technology                                       |
| OID     | Object Identifier                                                                    |
| PAA     | Policy Approval Authority                                                            |
| PEN     | Private Enterprise Number, assigned by IANA                                          |
| PKI     | Public Key Infrastructure                                                            |
| POWM    | Proof of Wi-SUN Membership                                                           |
| RA      | Registration Authority                                                               |
| RFC     | Request for Comments (at IETF.org)                                                   |
| SHA     | Secure Hashing Algorithm                                                             |
| TLS     | Transport Layer Security                                                             |
| TPS     | Technical Profile Specification (Wi-SUN FAN)                                         |
| X.509   | The ITU-T standard for Certificates and their corresponding authentication framework |

## Definitions

| Definition                     | Description                                                                                                                                                                                                                                                                          |
|--------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Applicant                      | An entity applying for a Certificate.                                                                                                                                                                                                                                                |
| Authentication Server          | The AAA server, typically a RADIUS server, that terminates EAP-TLS for a Field Area Network and decides whether a node is admitted. A relying party under this CP/CPS.                                                                                                               |
| Border Router                  | The node that connects a Field Area Network to a backhaul network, admits nodes and manages group keys. A relying party under this CP/CPS.                                                                                                                                           |
| Certificate                    | An electronic document, conformant to X.509v3, digitally signed by a Certificate Authority, that binds a Public Key to an identity.                                                                                                                                                  |
| Certificate Management System  | The keys, software and hardware used to verify Certificate Data, maintain a Repository, and issue Certificates.                                                                                                                                                                      |
| Certificate Management Process | The policies, practices, and procedures governing the use of the Certificate Management System                                                                                                                                                                                       |
| Certificate Problem Report     | A report of suspected Key Compromise, Certificate misuse, Certificate mis-issuance, or any other type of fraud, compromise, misuse or inappropriate conduct related to a Certificate. In this CP/CPS it is the trigger for the actions of section 4.9, revocation being unavailable. |

| Definition                      | Description                                                                                                                                                                                                                                                         |
|---------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Chain bundle                    | The set of CA certificates comprising every CA certificate between an IDevID and the Root CA, together with the Root CA certificate, delivered alongside the IDevID so that it can be provisioned into a device or into a relying party's chain material.           |
| Compromise notice               | A notice published by the OWGTM under section 4.9.1 identifying certificates that relying parties should cease to trust. It has no cryptographic effect.                                                                                                            |
| Field Area Network (FAN)        | The Wi-SUN network profile for utility and smart-city field devices, defined by the Wi-SUN FAN Technical Profile Specification.                                                                                                                                     |
| Hardware Crypto Module          | A tamper-resistant device, with a cryptography processor, used for the specific purpose of protecting the lifecycle of cryptographic keys (generating, managing, processing, and storing).                                                                          |
| hardwareModuleName              | The <b>otherName</b> form of RFC 4108, identified by OID 1.3.6.1.5.5.7.8.4, comprising <b>hwType</b> and <b>hwSerialNum</b> . It carries the device identity in a Wi-SUN IDevID, the subject field being empty.                                                     |
| hwSerialNum                     | The OCTET STRING component of a hardwareModuleName, carrying the serial number of an individual device, unique within its <b>hwType</b> .                                                                                                                           |
| hwType                          | The OBJECT IDENTIFIER component of a hardwareModuleName, allocated beneath the Manufacturer's IANA Private Enterprise Number arc and identifying the product model.                                                                                                 |
| IDeVID                          | An Initial Device Identifier: a device certificate installed at manufacture, which in the Wi-SUN hierarchy never expires and is never revoked.                                                                                                                      |
| Issuer CA                       | Any CA issuing Certificates under this CP/CPS                                                                                                                                                                                                                       |
| Key Compromise                  | A Private Key is said to be compromised if its value has been disclosed to an unauthorized person, or an unauthorized person has had access to it.                                                                                                                  |
| Key Pair                        | A Private Key and associated Public Key.                                                                                                                                                                                                                            |
| LDevID                          | A Locally Significant Device Identifier, issued by a network operator to a node after enrolment. Out of scope of this CP/CPS, as stated in section 1.4.2.                                                                                                           |
| Manufacturer CA (MCA)           | A Wi-SUN Subordinate CA, subordinate to the Root CA, that certifies Manufacturer Issuing CAs and issues no end-entity certificates.                                                                                                                                 |
| Manufacturer Issuing CA (MICA)  | A Wi-SUN Subordinate CA that issues Wi-SUN IDevIDs, subordinate either to an MCA or directly to the Root CA.                                                                                                                                                        |
| Manufacturer                    | The legal person that produces, or contracts the production of, a Wi-SUN FAN device, holds Wi-SUN Alliance membership, and is responsible for the accuracy of the identifiers placed in the Certificates issued to that device. The Manufacturer is the Subscriber. |
| Private Enterprise Number (PEN) | A number assigned by IANA to an organization, forming the arc 1.3.6.1.4.1.<PEN> beneath which that organization may allocate its own object identifiers.                                                                                                            |

| Definition                        | Description                                                                                                                                                                                                                                                                                                                         |
|-----------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Private Key                       | The key of a Key Pair that is kept secret by the holder of the Key Pair, and that is used to create digital signatures and/or to decrypt electronic records or files that were encrypted with the corresponding Public Key.                                                                                                         |
| Proof of Wi-SUN Membership (POWM) | Evidence issued by Wi-SUN Alliance member services that an organization is a Promoter or Contributor member in good standing. A precondition for the issuance of Wi-SUN IDevIDs.                                                                                                                                                    |
| Public Key                        | The key of a Key Pair that may be publicly disclosed by the holder of the corresponding Private Key and that is used by a Relying Party to verify digital signatures created with the holder's corresponding Private Key and/or to encrypt messages so that they can be decrypted only with the holder's corresponding Private Key. |
| Relying Party                     | An entity that relies upon the information contained within a Certificate. In this CP/CPS, principally a network operator's Authentication Server or Border Router, and other Wi-SUN FAN nodes.                                                                                                                                     |
| Relying Party Agreement           | An agreement which must be read and accepted by the Relying Party prior to validating, relying on or using a Certificate.                                                                                                                                                                                                           |
| Retirement                        | The withdrawal of a Certification Authority from service under section 4.9.1.2. It replaces revocation, which is unavailable in this hierarchy, and takes effect only when relying parties act on the published notice.                                                                                                             |
| Subject Identity Information      | Information that identifies the Certificate Subject. For a Wi-SUN IDevID this is the hardwareModuleName of section 7.1.4, the subject field being empty.                                                                                                                                                                            |
| Subscriber                        | The entity identified as responsible for the Certificate. For Wi-SUN IDevIDs the Subscriber is the Manufacturer, not the device.                                                                                                                                                                                                    |
| Subscriber Agreement              | An agreement that governs the issuance and use of a Certificate that the Applicant must read and accept before receiving a Certificate.                                                                                                                                                                                             |
| Wi-SUN Alliance                   | The industry alliance that publishes the Wi-SUN FAN specifications, operates the associated certification programme, approves the Certification Authorities permitted to issue Wi-SUN IDevIDs, and issues Proof of Wi-SUN Membership.                                                                                               |
| Wi-SUN Requirements               | Any requirement applicable to PKI services, certificate profiles or device identity that is published by the Wi-SUN Alliance and formally adopted by the PAA for the Wi-SUN hierarchy, as listed in Appendix D.                                                                                                                     |
| Wi-SUN Subordinate CA             | A Certification Authority beneath the Wi-SUN Root CA, authorised by the PAA to operate at the MCA or the MICA tier as stated in section 7.1. Used as the umbrella term for both tiers.                                                                                                                                              |

## Appendix B: CA Hierarchies

### Wi-SUN Root

The Wi-SUN hierarchy is anchored in a dedicated Root CA, issued on 6 March 2025 with no well-defined expiry. It is recognised by the Wi-SUN Alliance as the root of an approved third-party Certification Authority. It is not cross-signed by any Wi-SUN Alliance root, and it anchors no certificate population other than the Wi-SUN one.

#### Ownership and governance

The Root CA identified below is **owned by SealSQ Corp.**, which holds the certificate and the corresponding private key. This differs from the Root CAs described elsewhere in the OISTE/WISeKey Global Trust Model, which are owned by the OISTE Foundation, and the distinction is stated here so that it is not inferred from the body of this document.

Ownership of the Root does not carry authority over the policies applied beneath it. The trust model, the policies and the certification practices governing the Wi-SUN hierarchy are regulated by the **OISTE Foundation**, through its Policy Approval Authority, under the terms of section 1.5. In particular the PAA, and not the owner of the Root: - approves this CP/CPS and every amendment to it; - authorises each Wi-SUN Subordinate CA and the issuance of its certificate, under sections 3.2.2 and 3.2.6; and - conducts or commissions the assessments required by section 8, and may require a Subordinate CA to be retired under section 4.9.1.2.

SealSQ Corp., as owner of the Root, is bound to operate it in accordance with this CP/CPS and to execute the signing operations authorised by the PAA.

**Scope.** This CP/CPS governs the Wi-SUN Subordinate CAs listed below and the Wi-SUN IDevIDs issued beneath them. Test IDevIDs are issued from a separate hierarchy which is not trusted for production networks and is outside the scope of this document, as stated in section 1.4.2.

#### Root Information

| Field                  | Value                                                      |
|------------------------|------------------------------------------------------------|
| Subject Name           | C=CH, O=WISeKey, CN=SealSQ Wi-SUN Root CA G1               |
| Issuer Name            | C=CH, O=WISeKey, CN=SealSQ Wi-SUN Root CA G1 (self-signed) |
| Serial Number          | 33:5C:1D:AE:CE:48:18:F7:12:6F:29:2B:C0:A2:CF:94            |
| Subject Key Identifier | 73:3C:14:C9:31:9B:53:C5:1F:E2:D8:55:3A:8E:51:C3:AE:B0:5    |
| Fingerprint (SHA-256)  | F4:BE:70:32:7E:0B:57:E5:89:E0:F3:30:6B:83:06:B0:43:22:1    |
| Valid from             | 6 March 2025, 19:08:28 UTC                                 |
| Valid until            | 31 December 9999, 23:59:59 UTC — no scheduled expiration   |
| Public Key             | id-ecPublicKey, 256 bit, prime256v1 (NIST P-256)           |
| Signature Algorithm    | ecdsa-with-SHA256                                          |
| Key Usage              | critical: keyCertSign                                      |
| Basic Constraints      | critical: cA = TRUE, no pathLenConstraint                  |
| authorityKeyIdentifier | Not present                                                |
| Audit scope            | Wi-SUN IDevIDs                                             |

Relying parties **MUST** verify this fingerprint before installing the certificate as a trust anchor, as stated in section 6.1.4. Because the hierarchy publishes no revocation information, an incorrectly provisioned anchor cannot be corrected by any later action of the Certification Authority.

### Subordinate CA Information

The Subordinate CAs operating under this Root are listed below, at both the MCA and MICA tiers. This table is maintained by the PAA and republished whenever a Subordinate CA is added or retired. Subordinate CAs operated by a Manufacturer are marked as such and are constrained by configuration under section 7.1.5.

| Subject Name                                    | Fingerprint (SHA-256)     | Tier | Issued by | Operator | Allowed usage  |
|-------------------------------------------------|---------------------------|------|-----------|----------|----------------|
| <<<< TO BE COMPLETED AFTER THE CA CEREMONY >>>> | <<<< TO BE COMPLETED >>>> | MICA | Root CA   | WiSeKey  | Wi-SUN IDevIDs |

### Retired Subordinate CAs

Subordinate CA certificates cannot be revoked. A Subordinate CA that has been retired under section 4.9.1.2 is listed here so that network operators can remove the retired Subordinate CA certificate from the chain material held by the Authentication Server, or otherwise configure the server to reject chains that pass through it. A certificate listed in this table remains cryptographically valid and will continue to validate unless the operator acts.

| Subject Name                              | Fingerprint (SHA-256) | Tier | Date retired | Reason |
|-------------------------------------------|-----------------------|------|--------------|--------|
| <i>(none at the date of this version)</i> |                       |      |              |        |

## Appendix C: OID Inventory

OWGTM defines the following OID schema to identify the Certificate Policies issued under the Wi-SUN hierarchy.

PUBLIC-ARCH = 2.16.756.5.14

PUBLIC-ARCH.8 – Policy qualifiers for special purposes - 8.2 – Device certificates - 8.2.1 – CertifyID Device Certificate

PUBLIC-ARCH.8.4 – Wi-SUN Certificate Policies - 8.4.0 – OISTE/WiSeKey Wi-SUN CP/CPS (this document) - 8.4.1 – Wi-SUN Root CA CP - 8.4.2 – Wi-SUN Manufacturer CA (MCA) CP - 8.4.3 – Wi-SUN Manufacturer Issuing CA (MICA) CP - 8.4.4 – Wi-SUN IDevID CP

The MCA and MICA tiers carry distinct policy identifiers because they are subject to different constraints: an MCA may certify a further Certification Authority and a MICA may not, as stated in section 7.1.2.

The OID identifying this document is PUBLIC-ARCH.8.4.0, that is 2.16.756.5.14.8.4.0. This identifier is stable and does not carry the version number of the document: every version of this CP/CPS is identified by the same OID, and versions are distinguished by the version number stated in section 1.2 and in the revision table.

### External object identifiers used in the certificate profile

These OIDs are defined outside the OWGTM and are used in the profile of section 7.1. They are listed for the convenience of implementers and are not administered by the OWGTM.

| OID                 | Name                     | Defined by      |
|---------------------|--------------------------|-----------------|
| 1.3.6.1.4.1.45605.1 | id-kp-wisun-fan-device   | Wi-SUN Alliance |
| 1.3.6.1.5.5.7.3.2   | id-kp-clientAuth         | RFC 5280        |
| 1.3.6.1.5.5.7.8.4   | id-on-hardwareModuleName | RFC 4108        |
| 1.2.840.10045.4.3.2 | ecdsa-with-SHA256        | RFC 5758        |

| OID                 | Name                                                                                               | Defined by |
|---------------------|----------------------------------------------------------------------------------------------------|------------|
| 1.2.840.10045.2.1   | <b>id-ecPublicKey</b>                                                                              | RFC 5480   |
| 1.2.840.10045.3.1.7 | <b>secp256r1</b> (NIST P-256)                                                                      | RFC 5480   |
| 1.3.6.1.4.1.<PEN>   | Manufacturer Private Enterprise<br>Number arc, beneath which<br><b>hwType</b> values are allocated | IANA       |

## Appendix D: Adopted Wi-SUN Requirements

This appendix lists the documents published by the Wi-SUN Alliance that the PAA has formally adopted as “Wi-SUN Requirements” for the Wi-SUN hierarchy, in the sense of Appendix A and section 2.2.1. Where such a requirement conflicts with the body of this CP/CPS, the requirement prevails and the PAA shall amend this document at the next revision.

| Document                                   | Version | Date adopted by the PAA | Provisions adopted                                                                                                                                                                                                                                                             |
|--------------------------------------------|---------|-------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Wi-SUN FAN Technical Profile Specification | 1.1v06  | 2025-03-05              | Section 6.5.1 (Public Key Infrastructure: chain depth, key and signature algorithms, non-expiry, non-revocation) and section 6.5.1.1 (Wi-SUN IDevID construction: certificate fields, subjectAltName hardwareModuleName, extended key usage, prohibited revocation extensions) |
| Wi-SUN FAN Technical Profile Specification | 1.1v06  | 2025-03-05              | Section 6.5.3.2.1.3 (DevID certificate expiration and revocation)                                                                                                                                                                                                              |

Where this table is empty for a given matter, no Wi-SUN Requirement governs it and the stipulations of this CP/CPS apply in full.

**Considered and not adopted.** The PAA has reviewed the Wi-SUN Alliance material describing the policy and procedure for access to third-party Certification Authority services, and has not adopted it as a Wi-SUN Requirement. It governs the commercial process by which a manufacturer obtains an account and places orders, rather than certification practices or certificate profiles; it is not issued in a form on which normative reliance is appropriate; and it is distributed to members in confidence, so it could not be cited normatively in a public CP/CPS in any event. The operational consequences of that process that do bear on certification practice are stated directly in sections 3.2.2 and 9.1 of this document. The PAA will reconsider this if the Alliance issues a superseding version.